

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

USER APPENDIX B – STANDARD FOREST SERVICE INFORMATION TECHNOLOGY SECURITY LANGUAGE

1. CYBERSECURITY FOR CONTRACTS INVOLVING ACCESS TO GOVERNMENT INFORMATION, OR THE ACQUISITION OF INFORMATION SYSTEMS OR INFORMATION TECHNOLOGY (IT) SERVICES

1.1 By accepting this contract/agreement, the Contractor and other external organizations (hereafter called Contractor) providing Information Technology (IT) resources or services to the United States Forest Service (FS) agrees to comply with the applicable IT security policy as outlined in this document. The Contractor and other external organizations will be responsible for IT security for all systems connected to the FS network or operated by the Contractor and other external organizations for the FS, regardless of location. This clause is applicable to all or any part of the contract that includes IT resources or services in which the Contractor and other external organizations must have physical or logical access to FS information that directly support the mission of the FS. The term “information technology,” as used in this clause, means any equipment or interconnected system or subsystem of equipment that is used in the automatic acquisition, storage, manipulation, management, movement, control, display, switching, interchange, transmission, or reception of data or information. This includes both major applications and general support systems as defined by Office of Management and Budget (OMB) Circular A-130.

1.2 The substance of this entire section shall be included in all subcontracts under this contract.

1.3 The contractor shall comply with all security-related Federal Acquisition Regulation (FAR) clauses incorporated by the Contracting Officer (CO) in other parts of the solicitation.

1.4 The Contractor shall be responsible for properly protecting all information used, gathered, or developed as a result of work under this task. The Contractor shall also protect all unclassified Government data, equipment, etc., by treating information as sensitive business, confidential information, controlling and limiting access to the information, and ensuring the data and equipment are secured within their facility.



INFORMATION TECHNOLOGY PROCEDURE

SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES

Version: 7.2A

1.5 The Contractor or other external organization will not publish or disclose in any manner, without the FS Contracting Officer's written consent, the details of any programs, documentation, data, or safeguards either designed or developed by the Contractor or other external organization under this Contract or otherwise provided by the Government. The Contractor may be required to sign non-disclosure or other appropriate security agreements. A written agreement between the FS and any contractors and other external organizations will be entered into before FS data and information otherwise exempt from public disclosure may be disclosed to the contractors and other external organizations. The Contractor and other external organizations will agree to establish and follow security precautions considered by the FS to be necessary to ensure proper handling of data and information.

1.5.1 Data Rights. As may be identified elsewhere in this contract, the Contractor agrees that:

1.5.1.1 The draft and final deliverables and all associated working papers and other materials deemed relevant by the Contracting Officer's Representative (COR) that have been generated by the Contractor in the performance of this contract are the property of the United States Government and must be submitted to the COR at the conclusion of the tasks.

1.5.1.2 All documents produced for this project are the property of the United States Government and cannot be reproduced or retained by the Contractor.

1.5.1.3 Any information provided to the contractor by FS or collected by the contractor on behalf of FS shall be used only for the purpose of carrying out the provisions of this contract, and shall not be made known to any persons except as may be necessary in the performance of the contract.

1.5.1.4 FS will retain unrestricted rights to all federally owned and/or federally managed data and/or metadata that FS either owns or manages that is handled under this contract. Specifically, FS retains ownership of any user created/loaded data and applications collected, maintained, used, or operated on behalf of FS and hosted on contractor's infrastructure, as well as maintains the right to request full copies of these at any time. If requested, data shall be available to FS within one (1) business day from request date or within the timeframe specified and provided using an encryption standard that meets FS requirements. In addition, the data shall be provided at no additional cost to FS.



INFORMATION TECHNOLOGY PROCEDURE

SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES

Version: 7.2A

1.5.1.5 As part of contract closeout and at expiration of the contract, the contractor shall provide all required documentation, as specified by the Program Office, to the CO and/or COR to certify that, at the government's direction, all electronic and paper records are appropriately disposed of, and all devices and media are sanitized in accordance with NIST SP 800-88. Additionally, the contractor shall provide a certification that all government information has been properly sanitized and purged from contractor-owned systems, including backup systems and media used during contract performance, in accordance with FS and USDA policies. The contractor shall return all government information and IT resources (i.e., government information in nongovernment-owned systems, media, and backup systems) acquired during the term of this contract to the CO and/or COR.

1.6 Government Access for Security Assessment. To the extent required to carry out a program of security assessment (to include vulnerability testing), investigation, and audit to safeguard against threats and hazards to the availability, integrity, and confidentiality of Government data or information systems operated on behalf of FS, the Contractor, will, at any tier handling or accessing government information afford the Government access to the Contractor's or other external organization's facilities, installations, data centers, equipment (including but not limited to all servers, computing devices, and portable media), technical capabilities, operations, documentation (whether in electronic, paper, or other forms), records, and databases, and personnel used in performance of this contract, including, but not limited to:

1.6.1 The Government includes but is not limited to the U.S. Department of Justice, U.S. Government Accountability Office, and the USDA Office of the Inspector General (OIG). The Contractor will cooperate with Federal Government agencies and their officially credentialed representatives, or an independent third party working at the Government's direction, during official inspections or investigations concerning the protection of FS information and information systems.

1.6.2 Cooperation may include providing relevant documentation showing proof of compliance with federal and agency requirements, and rendering other timely and complete assistance and disclosure as deemed necessary to facilitate performance inspections and reviews, security and compliance audits, forensic analysis, law enforcement investigations, and identifying the nature and extent of any criminal or fraudulent activity and the individuals responsible. Cooperation also includes allowing the Government to make reproductions or copies of information and equipment, including, if necessary, collecting a machine or system image capture.

1.6.3 Logical commingling of Government protected information and metadata with other information is prohibited. Inspectors, auditors, and investigators will not be precluded from having access to the sought information if sought information is commingled with other information.

1.7 Threats, Hazards and Incidents.



INFORMATION TECHNOLOGY PROCEDURE

SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES

Version: 7.2A

1.7.1 If new or unanticipated threats or hazards are discovered by either the Government or the Contractor or other external organization, or if existing safeguards have ceased to function, the discoverer will **within no more than sixty (60) minutes of discovery**, bring the situation to the attention of the other party.

1.7.2 The Contractor shall report all suspected and confirmed information security and privacy incidents, breaches or violations, including incidents involving PII, in any medium or form, including paper, oral, or electronic, **within no more than sixty (60) minutes of discovery** to the USDA Cyber Watch Branch (CWB), by e-mail, at cyber.incidents@usda.gov, and to the COR.

1.8 **Privacy.** When the design, development, operation, or use of a system of records on individuals is required to accomplish an agency function, the Contractor will be required to design, develop, or operate a system of records on individuals subject to the Privacy Act of 1974, Public Law 93-579, December 31, 1974 (5 U.S.C. 552a) and applicable agency regulations. Violation of the Act may involve the imposition of criminal penalties.

1.8.1 The Contractor agrees to –

1.8.1.1 Comply with the Privacy Act of 1974 (the Act) and the agency rules and regulations issued under the Act in the design, development, or operation of any system of records on individuals to accomplish an agency function.

1.8.1.2 Include the Act notification contained in this contract in every solicitation and resulting subcontract and in every subcontract awarded without a solicitation, when the work statement in the proposed subcontract requires the redesign, development, or operation of a system of records on individuals that is subject to the Act; and

1.8.1.3 Include this clause, including this paragraph (3), in all subcontracts awarded under this contract that requires the design, development, or operation of such a system of records.

1.8.2 In the event of violations of the Act, a civil action may be brought against the agency involved when the violation concerns the design, development, or operation of a system of records on individuals to accomplish an agency function, and criminal penalties may be imposed upon the officers or employees of the agency when the violation concerns the operation of a system of records on individuals to accomplish an agency function. For purposes of the Act, when the contract is for the operation of a system of records on individuals to accomplish an agency function, the Contractor is considered to be an employee of the agency.



INFORMATION TECHNOLOGY PROCEDURE

SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES

Version: 7.2A

1.8.3 The contractor shall comply with OMB Memorandum M-17-12, *Preparing for and Responding to a Breach of Personally Identifiable Information*,” and with the USDA incident response policies when handling PII breaches.

1.8.4 Definitions include:

1.8.4.1 “Operation of a system of records,” as used in this clause, means performance of any of the activities associated with maintaining the system of records, including the collection, use, and dissemination of records.

1.8.4.2 “Record,” as used in this clause, means any item, collection, or grouping of information about an individual that is maintained by an agency, including, but not limited to, education, financial transactions, medical history, and criminal or employment history and that contains the person’s name, or the identifying number, symbol, or other identifying particular assigned to the individual, such as a fingerprint or voiceprint or a photograph.

1.8.4.3 “System of records on individuals,” as used in this clause, means a group of any records under the control of any agency from which information is retrieved by the name of the individual or by some identifying number, symbol, or other identifying particular assigned to the individual.

1.8.4.4 “Personally Identifiable Information”, as used in this clause, means information that can be used to distinguish or trace an individual's identity, either alone or when combined with other information that is linked or linkable to a specific individual. (See Office of Management and Budget (OMB) Circular A-130, Managing Federal Information as a Strategic Resource).

1.8.4.5 “Breach” or “Privacy Breach,” as used in this clause, a type of incident and is defined by FISMA as the loss of control, compromise, unauthorized disclosure, unauthorized acquisition, or any similar occurrence where (1) a person other than an authorized user accesses or potentially accesses personally identifiable information or (2) an authorized user accesses or potentially accesses personally identifiable information for any other-than-authorized purpose.

1.8.5 The FS will provide initial privacy training, and annual privacy training thereafter, to Contractor employees for the duration of this contract. All contractor/employees assigned to work on this contract shall complete the applicable USDA Cybersecurity and Privacy Awareness training (provided upon contract award) before performing any work under this contract (this training is available to new contractors, even if they do not have a Personal Identity Verification (PIV) card). Thereafter, the employees shall complete the USDA Cybersecurity and Privacy

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

Awareness training at least annually, during the life of this contract. All provided training shall be compliant with FS/USDA training policies. The contractor must maintain records of course completion and provide them to the Contracting Officer or Contracting Officer Representative upon request.

1.8.6 The Contractor shall not allow any employee access to a system of records, or permit any employee to create, collect, use, process, store, maintain, disseminate, disclose, dispose, or otherwise handle personally identifiable information, or to design, develop, maintain, or operate a system of records unless the employee has completed privacy training, as required by this clause.

1.8.7 The substance of this clause, including this paragraph, shall be included in all subcontracts under this contract, when subcontractor employees will:

1.8.7.1 Have access to a system of records;

1.8.7.2 Create, collect, use, process, store, maintain, disseminate, disclose, dispose, or otherwise handle personally identifiable information; or

1.8.7.3 Design, develop, maintain, or operate a system of records.

1.8.8 The contractors and other external organizations will ensure that the following banner is displayed on all FS systems that contain Privacy Act information operated by the contractors and other external organizations prior to allowing anyone access to the system:

“This system contains information protected under the provisions of the Privacy Act of 1974 (Public Law 93-579). Any privacy information displayed on the screen or printed must be protected from unauthorized disclosure. Employees who violate privacy safeguards may be subject to disciplinary actions, a fine of up to \$5,000, or both.”

1.9 Safeguarding Government Information

1.9.1 Records Management. The contractor shall maintain all information in accordance with National Archives and Records Administration (NARA) and FS records retention policies and schedules, and shall not dispose of any records unless authorized by FS. All contractors shall complete the applicable FS/USDA records management training at least annually during the life of this contract, in accordance with USDA and FS Records Management or Contracting policies and procedures.



INFORMATION TECHNOLOGY PROCEDURE

SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES

Version: 7.2A

1.9.2 The contractor shall be accountable and document all activities associated with the transport of government information, devices, and media transported outside controlled areas and/or facilities. These include information stored on digital media (e.g., CD- ROM, tapes, etc.), non-digital media (e.g., paper), and mobile/portable devices (e.g., USB (Universal Serial Bus) flash drives, external hard drives, and SD (Secure Digital) cards).

1.9.3 All information, devices and media shall be encrypted with FS-approved encryption mechanisms to protect the confidentiality, integrity, and availability of all government information transported outside of controlled facilities.

1.9.4 The contractor shall ensure all electronic and paper records are appropriately disposed of, and all devices and media are sanitized, in accordance with NIST SP 800-88 Rev 1, Guidelines for Media Sanitization.

1.9.5 Controlled Unclassified Information (CUI). The contractor shall comply with Executive Order 13556, and DR 3440-002, *Controlled Unclassified Information Program*, when handling Controlled Unclassified Information. The term “handling” refers to any use of CUI, including but not limited to marking, safeguarding, transporting, disclosing, disseminating, re- using, disposing, or destroying of the information. All sensitive information that has been identified as CUI by a regulation or statute, handled by this solicitation/contract, shall be:

1.9.5.1 Marked appropriately;

1.9.5.2 Disclosed to authorized personnel on a “Need-To-Know” basis;

1.9.5.3 Protected in accordance with the current, finalized version of NIST SP 800-53, Security and Privacy Controls for Federal Information Systems and Organizations applicable baseline if handled by a Contractor system operated on behalf of the agency, or NIST SP 800-171, Protecting Controlled Unclassified Information in Nonfederal Information Systems and Organizations if handled by internal Contractor system; and

1.9.5.4 Returned to FS/USDA control, destroyed when no longer needed, or held until otherwise directed. Destruction of information and/or data shall be accomplished in accordance with NIST SP 800-88, Guidelines for Media Sanitization.

1.10 Desktops, Laptops, and Other Computing Devices. The contractor shall ensure that all IT equipment (e.g., laptops, desktops, servers, routers, mobile devices, peripheral devices, etc.) used to process information on behalf of FS are deployed and operated in accordance with approved security configurations and meet the following minimum requirements:

1.10.1 Maintain the latest operating system patch release and anti-virus software definitions;



INFORMATION TECHNOLOGY PROCEDURE

SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES

Version: 7.2A

1.10.2 Encrypt equipment and information stored and/or processed by such equipment in accordance with FS/USDA and FIPS 140-3, as amended, encryption standards;

1.10.3 Configure laptops and desktops in accordance with the latest applicable United States Government Configuration Baseline (USGCB), Program Office specific security configuration baseline, if any has been provided to the contractor, and USDA Minimum Security Configuration Standards;

1.10.4 Validate the configuration settings after hardware and software installation, operation, maintenance, update, and patching and ensure changes in hardware and software do not alter the approved configuration settings; and

1.10.5 Automate configuration settings and configuration management in accordance with FS/USDA security policies.

1.11 **Encryption.** The contractor shall:

1.11.1 Comply with Executive Order (EO) 14028, Improving the Nation's Cybersecurity (May 12, 2021), Section 3(d)(iii) requirements for encrypting data at rest and data in transit as well as FS/USDA policies and procedures.

1.11.2 Encrypt all federal data and information (i.e., PII, proprietary information, Controlled Unclassified Information, etc.) in transit (i.e., email, network connections, etc.) and at rest (i.e., servers, storage devices, mobile devices, backup media, etc.) with FIPS 140-3, as amended, validated encryption solution.

1.11.3 Secure all devices (i.e.: desktops, laptops, mobile devices, etc.) that store and process federally owned or federally managed information and ensure devices meet FS/USDA-specific encryption standard requirements.

1.11.4. Maintain a complete and current inventory of all laptop computers, desktop computers, and other mobile devices and portable media that store or process government information (including PII).

1.11.5 Verify that the encryption solutions in use have been validated under the Cryptographic Module Validation Program to confirm compliance with FIPS 140-3. The contractor shall provide a written copy of the validation documentation to the COR when required by the Program Office.

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

1.11.6 Use the Key Management system on the USDA personal identification verification (PIV) card or establish and use a key recovery mechanism to ensure the ability for authorized personnel to encrypt/decrypt information and recover encryption keys. Encryption keys shall be provided to the CO, COR, or to the Project Manager or Program Manager, upon request and at the conclusion of the contract.

1.12 Cyber Supply Chain Security

1.12.1 Cyber Supply Chain Risk Management Requirements. The Contractor shall comply with *USDA Cyber Supply Chain Risk Management (C-SCRM) Contract Language* (included in Section 9 of this appendix).

1.12.2 Notification of Supply Chain Compromises: The Contractor shall develop, propose, and implement procedures for notifying the CO, as well as FS/USDA Cybersecurity personnel, of any compromises of its supply chain (in accordance with the “Threats, Hazards and Incidents” paragraph above and the *USDA Cyber Supply Chain Risk Management (C-SCRM) Contract Language*). Such procedures are subject to approval by the CO prior to implementation. [SR-08]

1.12.3 Data, Documentation, Tools, Or System Components Disposal: The Contractor shall ensure any data, documentation, tools, or system components containing controlled unclassified information (CUI) or other non-publicly-available information is properly sanitized using the processes specified in NIST SP-800-88 Rev. 1, *Guidelines for Media Sanitization*, prior to disposal.

1.13 Foreign Sourcing

1.13.1. The Contractor will comply with all requirements related to “Country of Origin” in the *USDA Cyber Supply Chain Risk Management (C-SCRM) Contract Language* (see Section 9 of this appendix). This includes the provision that the Contractor shall not use any product or its components (including hardware, software, and firmware) that are on the Department of Commerce Entity List, including countries where the development, manufacturing, maintenance, and service for the product are provided.

1.13.2. The Contractor shall comply with any FAR provisions included by the Contracting Officer concerning the use/acquisition of products or services from prohibited entities/sources.

1.14 **Non-U.S. Citizens.** The Contractor shall comply with the provisions of the USDA Office of Homeland Security (OHS) November 15, 2023, memorandum entitled Hiring Non-United States (U.S.) Citizens as Federal Employees or Federal Contractors, as directed and implemented by the FS program and Contracting Office officials.

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

2. SECURITY REQUIREMENTS FOR CONTRACTOR/COOPERATOR BUILDING ACCESS AND/OR INFORMATION SYSTEM ACCESS

2.1 The Contractor shall insert these clauses in all subcontracts when the subcontractor is required to have routine physical access to a federally controlled facility and/or routine access to a federally controlled system. Failure to comply with said requirements will constitute cause for termination.

2.2 IT Security Training:

2.2.1 Mandatory Training for All Contractor Staff. All contractor/employees assigned to work on this contract shall complete the applicable USDA Cybersecurity and Privacy Awareness training (provided upon contract award) before performing any work under this contract (this training is available to new contractors, even if they do not have a PIV card). Thereafter, the employees shall complete the USDA Cybersecurity and Privacy Awareness training at least annually, during the life of this contract. In accordance with the 1-Nov-2023 memorandum from the USDA Office of Contracting and Procurement (OCP), all contractor employees who will access USDA's IT systems/network will automatically have AgLearn access, and must complete the Information Security Awareness training courses in AgLearn. The contractor must ensure their employees (including subcontractor personnel) complete the training course(s) listed below in the frequency identified.

Course Name	Frequency	Method of Training	Length of Training	Completion Date
Information Security Awareness	Annually	AgLearn	60 minutes	1 year since last completion date

2.2.2 Role-based Training. All contractor employees with significant security responsibilities (as determined by the program manager or generally, any individual who has any security responsibilities that are more than the security responsibilities that any end-user would have, e.g., an Information System Security Officer, an Information System Security Manager, or any individual working within the Information Assurance Services division of the Office of the Chief Information Officer) must complete role-based training annually in accordance with FS/USDA policy.

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

2.2.3 Training Records. The contractor shall maintain training records for all its employees working under this contract in accordance with FS/USDA policy. A copy of the training records shall be provided to the CO and/or COR within 30 days after contract award and annually thereafter, or upon request.

2.3 Rules of Behavior:

2.3.1 The contractor shall ensure that all employees performing on the contract sign and comply with the applicable FS/USDA Rules of Behavior (ROB) and any specific rules provided by the Program Office.

2.3.2 All contractor employees performing on the contract shall read and adhere to the Rules of Behavior before accessing Department data or other information, systems, and/or networks that store/process government information, initially at the beginning of the contract and at least annually thereafter, which may be done as part of annual USDA Cybersecurity and Privacy Awareness training.

2.3.3 Employees, contractors, and anyone assigned to a contract shall sign Rules of Behavior (RoB). Signed copies of RoB shall be kept on file by the Contractor's program manager.

2.4 **Background Investigations:** All non-government employees with unescorted access to FS facilities, computer systems and/or FS information must have background investigations commensurate with the level of risk and magnitude of loss or harm. The FS will determine the level of background investigation and position classification needed.

2.5 **Personal Identity Verification of Contractor Personnel:** The Contractor shall be responsible for ensuring compliance by its employees with all applicable federal regulations, to include those of GSA, NIST, USDA, FS and HSPD-12. Contractors and their employees are subject to all Federal laws applicable to Government installations and are under the jurisdiction of the Federal Protective Service (FPS). The designated program/project officers, in conjunction with the FS HCM HSPD-12 staff, will assist the Contractor in processing the required Security Background Investigations/Clearances.

2.5.1 The Contractor shall comply with the personal identity verification (PIV) policies and procedures established by U.S. Department of Agriculture (USDA) Directives 3800 series.

2.5.2 Should the results of the PIV process require the exclusion of a Contractor's employee; the Contracting Officer will notify the Contractor in writing.

2.5.3 The Contractor must appoint a representative to manage this activity and to maintain a list of employees eligible for a USDA PIV ID Badge required for performance of the work.



INFORMATION TECHNOLOGY PROCEDURE

SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES

Version: 7.2A

2.5.4 The responsibility of maintaining a sufficient workforce remains with the Contractor. Employees may be barred by the Government from performance of the work should they be found ineligible or to have lost eligibility for a USDA PIV ID Badge. Failure to maintain a sufficient workforce of employees eligible for a USDA PIV ID Badge may be grounds for termination of the contract.

2.5.5 The Contractor shall insert this clause in all subcontracts when the subcontractor is required to have access to a federally controlled facility or system.

2.5.6 The PIV Sponsor for this contract is the Program Manager, or their delegated sponsor, unless otherwise specified in this contract. The PIV Sponsor will be available to receive contractor identity information from * (hours and days TBD) to * (hours and days TBD) at * (office address for registration TBD). The Government shall notify the Contractor if there is a change in the PIV Sponsor, the office address, or the office hours for registration.

2.5.7 At this time, the Government will pay for and process all required security investigations/clearances, except as identified differently within this clause.

2.5.8 The Contractor should be aware of any of its employees possibly having had a background investigation through another government agency. The investigation that was conducted, if verifiable by the FS HSPD-12 staff, and if it was completed within the last 5 years, can be accepted by the Government in lieu of a background check.

2.5.9 The Contractor shall comply with any facility badging requirements for the issuance of building access, badges, etc.:

2.5.9.1 Ensure that each of the Contractor's employees has been issued either a temporary or permanent badge from the Government. A permanent badge will not be issued until the security questionnaire has been completed and favorably reviewed. Temporary or visitor badges will be provided for persons who are identified as having an infrequent or temporary legitimate business need for access to the site. As noted above, periods that exceed 180 days will require a permanent badge. The badge must be worn at all times while in the facility. It must be displayed above the waist. The individual will retain possession of the badge as long as continued admittance to the site is needed.

2.5.9.2 Ensure the safekeeping, wearing, and visibility of Government-furnished badges.

2.5.9.3 Immediately return all badges and permits to the Government when such need ceases to exist.

2.5.10 The Contractor shall comply with any facility security requirements for access to the facility.

2.5.11 The Contractor shall comply with all applicable rules governing parking at FS/USDA

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

locations.

3.0 SECURITY FOR DEVELOPING AND/OR IMPLEMENTING SOFTWARE APPLICATIONS

3.1 The substance of this entire section shall be included in all subcontracts under this contract.

3.2 **Best Practices:** The contractor shall follow secure coding best practice requirements, as directed by the United States Cybersecurity and Infrastructure Security Agency (CISA) specified standards and the Open Web Application Security Project (OWASP) that will limit system software vulnerability exploits.

3.3 **Secure Coding Skills:** Contractor certifies that at least one member of each programming team working on any code (including C, Java, .Net, ASP.NET, Visual Basic) to be delivered to the Forest Service has earned the Global Information Assurance Certification for Secured Software Programming or equivalent.

3.4 **Source code testing, binary code testing, application scanning, and penetration testing:** At least one week prior to delivery of any code due under this contract, Contractor will deliver to the FS Program Manager, or delegated sponsor, the following reports covering all code that will be delivered:

3.4.1 Source code testing results showing all potential security flaws identified by at least one of the commercial source code testing tools approved by the Office of the Chief Information Officer of USDA. On the report, the Contractor will highlight all vulnerabilities rated “critical” and “high.” The Contractor must then correct the vulnerabilities, resend the code, and ensure the health of delivered source code.

3.4.2 For web applications, web application scanning test results showing all potential security flaws identified by at least one of the commercial web application scanning tools approved by the Office of the Chief Information Officer of USDA. On the report, the Contractor will highlight all vulnerabilities rated “critical” and “high.”

3.4.3 For all applications: application penetration results.

3.5 **End of Life Compliance:** The contractor shall use Commercial off the Shelf (COTS) software or other software that is supported by the manufacturer. In addition, the COTS/other software needs to be within one major version of the current version. Deviation from this requirement will only be allowed via the FS/USDA Risk-Based Decision (RBD) process. The contractor shall retire and/or upgrade all software/systems that have reached end-of-service-life. Under no circumstances will the Department allow contractors to utilize unsupported COTS applications, systems, components, programs or utilities without a specific written exception, signed and authorized by the CIO.

3.6 The contractor shall ensure IT applications designed and developed for end users (including

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

mobile applications and software licenses) run in the standard user context without requiring elevated administrative privileges.

3.7 Copyright Management and Responsibility: By delivering applications or programming code to the Federal Government, the vendor or Contractor certifies that they have the proper authority to transfer the property and will defend the Government against copyright or other lawsuit resulting from the application or programming delivered.

3.8 The contractor shall ensure that computer software developed on behalf of FS or tailored from an open-source product, is fully functional and operates correctly with least privilege on systems configured in accordance with government policy and federal configuration standards. The contractor shall test applicable products and versions with all relevant and current updates and patches updated prior to installing in the FS/USDA environment. No sensitive data shall be used during software testing.

3.9 Multifactor Authentication. In accordance with Executive Order (EO) 14028, OMB M-22-09, *Moving the U.S. Government Toward Zero Trust Cybersecurity Principles*, and OMB M-19-17, *Enabling Mission Delivery through Improved Identity, Credential, and Access Management*, the contractor shall ensure applications support multifactor authentication (MFA), including phishing resistant solutions, as appropriate.

3.10 Vulnerability Identification and Remediation.

3.10.1 The contractor shall remediate security risks for which they are responsible, including those identified during their own development, included third party open-source software packages, scanning and testing activities, as well as those identified during testing, A&A and continuous monitoring activities by the government or its designated representatives. The Contractor shall report vulnerabilities identified in any component through scans or other methods. The FS shall determine the risk rating of all identified vulnerabilities.

3.10.2 In providing the products and services described in this Agreement the Contractor shall provide, at no additional cost to the government, appropriate software and firmware updates to remediate newly discovered vulnerabilities or weaknesses within the prescribed timelines: Critical vulnerabilities shall be remediated within 14 days from discovery; and all High, Medium, and Low vulnerabilities shall be mitigated within 30 days from discovery. A shorter timeframe may be required by CISA in a Binding Operational Directive or Emergency Directive. In the event that a specific vulnerability or other risk finding cannot be remediated within the prescribed timelines above, variance from the timeline must be approved by FS in accordance with the USDA Plan of Action and Milestones (POA&M) Standard Operating Procedures (SOP), and shall be added to the designated POA&M and remediated within the newly designated timelines specified by the Program Office.

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

4.0 SECURITY FOR EXTERNAL IT SERVICES (PROCESSING, STORING, OR TRANSMITTING FS DATA ON A NON-FS SYSTEM)

Note: An external service is an external entity that provides a service that requires access to FS information.

- 4.1 The substance of this entire section shall be included in all subcontracts under this contract.
- 4.2 The Contractor or other external organizations will develop, provide, implement, and maintain an IT System Security Plan for any system that includes acquisition, transmission or analysis of data owned by FS with significant replacement cost should the Contractor's and other external organization's copy be corrupted. This plan will describe the processes and procedures that will be followed to ensure appropriate security of IT resources that are developed, processed, or used under this contract. The plan will describe those parts of the contract to which this clause applies. The Contractor or other external organization's IT System Security Plan will be compliant with applicable Federal laws that include, but are not limited to: the Clinger-Cohen Act of 1996, the Federal Information Security Management Act of 2002 (FISMA 2002), and the Federal Information Security Modernization Act of 2014 (FISMA 2014). The IT System Security Plan will meet IT security and privacy requirements in accordance with Federal and FS policies and procedures that include but are not limited to: National Institute of Standards and Technology (NIST) SP 800-53 Guidelines.
- 4.3 The Contractor and other external organizations will ensure that the appropriate security banners are displayed on all FS systems (both public and private) operated by the contractors and other external organizations prior to allowing anyone access to the system.

5.0 SECURITY REQUIREMENTS FOR GOVERNMENT-OWNED/CONTRACTOR-OPERATED AND CONTRACTOR-OWNED/CONTRACTOR-OPERATED INFORMATION SYSTEMS (I.E., EXTERNAL SYSTEMS)

Note: An external system is a system that is implemented outside of the authorization boundary of the FS system (i.e., a service that is used by, but not part of, the FS system) and for which the FS typically has no direct control over the application of required security and privacy controls, supply chain, or the assessment of security and privacy control effectiveness. Examples of external systems are service-oriented architectures (SOAs), a cloud-based system, or data center operations. A cloud-based system is software, infrastructure, or platform made available to users on demand via the Internet from a cloud service provider (CSP).

- 5.1 The substance of this entire section shall be included in all subcontracts under this contract.

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

5.2 The Contractor shall comply with all applicable directives to protect the confidentiality, integrity and availability of information systems owned or operated by a contractor that processes, stores, or transmits Forest Service (FS) information, including: the Federal Information Security Modernization Act of 2014 (FISMA); Executive Orders (EO); Office of Management and Budget (OMB); Cybersecurity and Infrastructure Security Agency (CISA); National Institute of Science and Technology (NIST); General Services Administration (GSA); United States Department of Agriculture (USDA); FS; and other applicable laws, regulations, guidance and policies.

5.3 The Contractor shall apply the basic safeguarding requirements and procedures to protect covered contractor information systems defined in [FAR 52.239.1](#), as well as those described in the rest of this section (subparagraphs 5.4 through 5.19).

5.4 **Security Assessment and Authorization (A&A).** The Contractor shall support the Assessment & Authorization (A&A) for the Authority to Operate (ATO) of the system, based on its NIST categorization, in accordance with NIST Special Publication (SP) 800-53, NIST SP 800-37, *Guide for Applying the Risk Management Framework to Federal Information Systems: A Security Life Cycle Approach*, and the current USDA Risk Management Framework (RMF) process documentation.

5.4.1 The Contractor must work with the FS and supply deliverables and support activities to support the A&A for the system, including the System Security and Privacy Plan (SSP); Contingency Plan (CP); Configuration Management Plan (CMP); Incident Response Plan (IRP); Disaster Recovery Plan (DRP); E-Authentication Threshold / Risk Assessment(s) or Questionnaire, if required; Privacy Threshold / Impact Assessment(s); CP and DRP Tests; and any other required documents to ensure the system shall receive an ATO.

5.4.2 Contractor must work with the FS to complete a security assessment / risk assessment of the system by the Forest Service's independent assessor, which is documented in a Security Assessment Report (SAR).

5.4.3 Gaps between required controls and Contractor's implementation identified in the SAR shall be documented, approved, and tracked for mitigation in a Plan of Action and Milestones (POA&M) document completed in accordance with USDA Plan of Action and Milestones (POA&M) Standard Operating Procedures (SOP). The Contractor shall provide initial and periodic technical input to FS in responding to POA&M items by identifying the intended mitigations, estimated costs, and expected timelines that may be **required to address security weaknesses**.

5.5 **Privacy Threshold Analysis (PTA)/Privacy Impact Assessment (PIA).**



INFORMATION TECHNOLOGY PROCEDURE

SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES

Version: 7.2A

5.5.1 The contractor shall assist the FS and USDA privacy officials or designee in reviewing the PTA and PIA annually for the information system and/or information handled under this contract to determine whether or not a full PIA needs to be completed. If the results of the PTA show that a full PIA is needed, the contractor shall assist the FS and USDA privacy officials or designee with completing a PIA for the system or information within the timeframe required by the Program Office after completion of the PTA and in accordance with FS and USDA policy and OMB M-03-22, Guidance for Implementing the Privacy Provisions of the E-Government Act of 2002. The contractor shall assist the FS and USDA privacy officials in reviewing the PIA at least annually throughout the system development lifecycle (SDLC)/information lifecycle, or when determined by the agency that a review is required based on a major change to the system, or when new types of PII are collected that introduces new or increased privacy risks, whichever comes first.

5.5.2 For contracts subject to the Privacy Act of 1974, the contractor shall support a system of records and any applicable System or Record Notices (SORNs), in conjunction with the judgment of the Senior Agency Official for Privacy (SAOP), and NARA-approved records schedule(s) and protection requirements for federal agencies to manage their electronic records in accordance with 36 CFR § 1236.20 & 1236.22 (ref. a), including but not limited to maintenance of links between records and metadata, and categorization of records to manage retention and disposal, either through transfer of permanent records to NARA or deletion of temporary records in accordance with NARA- approved retention schedules.

5.6 The Contractor shall work with the FS and provide appropriate solutions and controls to implement the provisions of Executive Order (EO) 14028, *Improving the Nation's Cybersecurity* and other related directives and guidance from OMB, the Cybersecurity and Infrastructure Security Agency (CISA), USDA, FS, and the information system owner. This includes, but is not limited to:

5.6.1 Audit logging, in accordance with OMB M-21-31, *Improving the Federal Government's Investigative and Remediation Capabilities Related to Cybersecurity Incidents*. The Contractor shall collect and preserve data, information, and reporting relevant to cybersecurity event prevention, detection, response, and investigation on all information systems over which they have control, including systems operated on behalf of government. The Contractor shall share such data, information, and reporting, as they relate to cyber incidents or potential incidents relevant to FS.

5.6.2 Zero Trust Architecture (ZTA), in accordance OMB M-22-09, *Moving the U.S. Government Toward Zero Trust Cybersecurity Principles*; and

5.6.3 Identification and Authentication. The contractor shall:

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

5.6.3.1 Comply with EO 14028 Section 3(d) requirements for implementing multi-factor authentication (MFA), as well as FS/USDA Identification and Authentication (IA) standards to prevent unauthorized access to government information.

5.6.3.2 Require MFA--including phishing resistant solutions as appropriate--in accordance with OMB M-22-09 and OMB M-19-17, *Enabling Mission Delivery through Improved Identity, Credential, and Access Management*.

5.7 The Contractor shall conduct and document ongoing Asset Management and Configuration Management for all hardware and software components, to include:

5.7.1 Using any available Security Content Automation Protocol (SCAP)-compliant automated tools for active/passive scans, provide an inventory of all information technology (IT) assets for hardware and software (computers, servers, routers, databases, operating systems, application, etc.) that are processing FS/USDA-owned information/data.

5.7.2 Using available SCAP-compliant automated tools for authenticated scans to provide visibility into the security configuration compliance status of all IT assets, (computers, servers, routers, databases, operating systems, application, etc.) that store and process government information.

5.7.3 Maintaining the tools and capabilities to support asset discovery, to include passive network monitoring, active network monitoring, and automated network mapping.

5.8 The Contractor shall conduct and document an ongoing Vulnerability Management program, including vulnerability scans, penetration testing, installation of vendor-released security patches, or other vulnerability remediations for the information system and its components.

The contractor shall use automated tools to perform authenticated scans that detect any security vulnerabilities in 100% of IT assets (computers, servers, routers, websites, web applications, databases, operating systems, etc.) that store and process government information. Vulnerability scans shall occur at least every 72 hours in accordance with CISA Continuous Diagnostics and Mitigation (CDM) guidance.

The Contractor shall actively manage system vulnerabilities using SCAP-compliant automated tools and technologies where practicable and in accordance with FS/USDA policy & Federal Directives. The Contractor shall report vulnerabilities identified in any component through scans or other methods. The Contractor shall maintain a capability to provide security vulnerability scanning information for 100% of IT assets and report to FS at least weekly, or more frequently as required by Department Policy.

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

The FS shall determine the risk rating of all identified vulnerabilities. All critical vulnerabilities must be remediated within 14 days and all High, Medium, and Low vulnerabilities must be remediated within 30 days from the date vulnerabilities are identified. A shorter timeframe may be required by CISA in a Binding Operational Directive or Emergency Directive. Variance from approved mitigation must be approved in accordance with USDA POA&M SOP.

5.9 The Contractor shall ensure that government information, other than unrestricted information, being transmitted from federal government entities to external entities is routed through a Trusted Internet Connection (TIC) as defined in TIC 3.0 guidance documentation established by CISA. The Contractor shall route all external connections through a TIC, and include the capability for network traffic that flows between externally hosted systems and networks, to/from FS systems and networks, to be routed through one of the USDA TIC gateways as part of the solution configuration. The Contractor shall implement controls ensuring all traffic, including mobile and cloud, goes through approved traditional TIC gateways or TIC 3.0 security architecture and capabilities.

5.10 **Continuous Monitoring / Ongoing Security Assessment & Authorization.** Following the issuance of an ATO, contractors shall support continuous monitoring activities to identify and remediate risks while monitoring changing conditions which could potentially affect the ability to conduct core missions and business functions. The Contractor must work with the FS and supply deliverables and implement activities to support Continuous Monitoring of the system, including annual reviews and updates of ATO documentation such as an SSP, CP, CMP, IRP, DRP and SAR; required testing of CP, DRP and IRP; and POA&M updates.

5.11 As part of Continuous Monitoring, the Contractor must provide requested artifacts, and response to queries, regarding contractor's security control implementation and practices needed to support the Forest Service demonstrating on-going compliance with Federal security requirements.

5.12 The Contractor shall ensure that information systems or services provided to the FS adhere to all applicable Department of Homeland Security cybersecurity Binding Operational Directives (BODs) and Emergency Directives requirements (<https://cyber.dhs.gov/directives/>).

5.13 The Contractor shall prepare, and monitor for, any security incidents.

5.13.1 The contractor shall protect FS/USDA information resources with regularly run automated detection tools. These tools will use updated indicators whether the tool vendors, USDA Cybersecurity and Privacy Operations Center (CPOC), or CISA provides them. The contractor shall review tool-based alerts, and provide results to FS Cybersecurity or other authorized parties.



INFORMATION TECHNOLOGY PROCEDURE

SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES

Version: 7.2A

5.13.1.1 Maintain tools and capabilities to support behavior monitoring, to include NetFlow analysis and network traffic capture, which captures the Transmission Control Protocol/Internet Protocol (TCP/IP) stream, allowing for replay of activity to determine what happened during a breach or incident.

5.13.1.2 Maintain tools and capabilities for intrusion prevention, to include host intrusion prevention systems (HIPS) and network intrusion prevention systems (NIPS).

5.13.1.3 Maintain a firewall system designed to prevent unauthorized access to or from any contractor systems and network, and externally facing web application firewall capabilities providing inbound and outbound traffic filtering.

5.13.1.4 Maintain tool and capabilities to perform Security Incident/Event Management and Analysis, to include centralized logging, log correlation, and a Security Information and Event Management (SIEM) solution.

5.13.1.5 Maintain tools and capabilities to provide security situational awareness and visibility throughout the enterprise;

5.13.1.6 Provide and maintain automated means of discovering, monitoring, and protecting sensitive data to ensure protection of data in motion, at rest, and in use.

5.13.1.7 Perform periodic penetration testing, and also support external agency penetration testing, red team testing, cyber hygiene web site vulnerability scanning tests and vulnerability assessments that the Department may need to conduct (this may involve testing conducted by the agency or independent third-party.).

5.13.2 The Contractor shall develop, maintain, and implement an incident management plan if they use their own system or service to generate, collect, provide, transmit, store, or maintain FS/USDA data. The contractor shall share the plan with FS Cybersecurity, test the plan at least annually, and share the test results with FS Cybersecurity.

5.14 The Contractor shall report, and respond to mitigate as required, any security incidents.

5.14.1 The contractor shall respond to all alerts/Indicators of Compromise (IOCs) provided by either the USDA SOC, ISSO, the Project Manager, the Program Manager, the CO, the COR, the SAOP (or designee), or the CISO (or designee) **within 24 hours**, whether the response is positive or negative.

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

5.14.2 In the event of a suspected or confirmed incident or breach, the contractor shall:

5.14.2.1 Report, **within no more than sixty (60) minutes of discovery**, consistent with the applicable USDA policy and procedures, NIST standards and guidelines, as well as with CISA notification guidelines. The types of information required in an incident report shall include at a minimum: company and point of contact information, contract information, impact classifications/threat vector, and the type of information compromised. Reports shall encrypt sensitive information in attachments to email, media, etc., and shall NOT include any sensitive information in the subject or body of any reporting e-mail.

5.14.2.2 Provide full access, cooperate and exchange any information on all activities necessary to effectively manage or mitigate a suspected or confirmed breach as determined by the United States Government. The U.S. Government in this case, includes, but is not limited to: FS, USDA, any involved law enforcement or Department of Defense (DoD) agencies, such as The Department of Homeland Security (DHS), Cybersecurity and Infrastructure Security Agency (CISA), the Federal Bureau of Investigation (FBI), the Central Intelligence Agency (CIA), the National Security Agency (NSA), the Defense Information Systems Agency (DISA), or the Office of Personnel Management (OPM) etc.

5.14.2.3 Refrain from notifying affected individuals unless so instructed by the contracting officer or designated representative. If instructed by the contracting officer or representative, the contractor shall send FS/USDA and Program Office approved notifications to affected individuals within the timeframe established by the Program Office.

5.15 Cloud and FedRAMP Security and Privacy Requirements

5.15.1 In accordance with the FedRAMP Authorization Act (part of the FY23 National Defense Authorization Act (NDAA)), Executive Order (EO) 14028, and OMB Memorandum M-24-15, *Modernizing the Federal Risk and Authorization Management Program (FedRAMP)*, the use of any cloud products or services in this acquisition may leverage authorization in accordance with FedRAMP procedures published by GSA, USDA and FS policies and procedures. Applicable USDA policies and procedures include, but are not limited to, the USDA RMF SOP and USDA FedRAMP SOP.

5.15.2 For systems where the program/system owner agrees to leveraging FedRAMP:

5.15.2.1 The contractor will comply with FedRAMP Assessment and Authorization (A&A) requirements and ensure the information system/service under this contract has a valid Federal Risk and Authorization Management Program (FedRAMP)-compliant (approved) ATO in accordance with Federal Information Processing Standard (FIPS)



INFORMATION TECHNOLOGY PROCEDURE

SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES

Version: 7.2A

Publication 199 defined security categorization. Such compliance includes making available any documentation, physical access, and logical access needed to support FS and USDA A&A requirements as needed.

5.15.2.2 The Contractor shall maintain FedRAMP accreditation and provide services detailed in the service level agreement.

5.15.2.3 The Contractor shall notify the system owner of significant changes to their FedRAMP status or FedRAMP approved cloud services (e.g., revocation of FedRAMP accreditation, vulnerabilities, exception requests).

5.15.2.4 The Contractor shall, as required, support FS in completing the A&A documentation for the “front-end” system, which documents those additional security controls which are required under NIST SP 800-53 and either shared or customer responsibility.

5.16 **Data Jurisdiction.** The Contractor shall store all information within the security authorization boundary, data at rest or data backup, within the Continental United States (CONUS).

5.17 The Contractor shall understand the terms of the service agreements that define the legal relationships between cloud customers and cloud providers and work with Program Office to develop and maintain a Service Level Agreement (SLA). The SLA will define: (1) Performance metrics, how they will be monitored, and penalties for failure to meet them; (2) Data lifecycle management and data element identification and disposition; (3) Roles, responsibilities, and reporting requirements; and (4) Both parties will be responsible for possessing the SLA.

5.18. **Web and E-mail Security.**

5.18.1 In accordance with OMB Memorandums M-08-23, *Securing the Federal Government’s Domain Name System Infrastructure*, M-17-06, *Policies and Requirements for Public Websites*, and M-23-10, *The Registration and Use of .gov Domains in the Federal Government*, in order to ensure Domain Name System Security (DNSSEC), the contractor shall use only an approved usda.gov domain . All websites that disseminate and/or do business on FS behalf of FS must adhere to these OMB memoranda.

5.18.2 All new and existing government websites shall be securely configured with Hypertext Transfer Protocol Secure (HTTPS) using the most recent version of Transport Layer Security (TLS). In accordance with OMB Memorandums M-17-06, and M-15-13, M-08-23, M-10-23, M-15-13, *Policy to Require Secure Connections across Federal Websites and Web Services*, CISA



INFORMATION TECHNOLOGY PROCEDURE

SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES

Version: 7.2A

BOD-18-01, and the NIST SP 800-52 and SP 800-44, the contractor shall ensure all Federal websites and web services developed, modified, or maintained, under this contract shall be accessible through a secure connection (HTTPS only, with HTTP Strict Transport Security HSTS).

5.18.3 The contractor shall comply with requirements specified in CISA Binding Operational Directive (BOD)-18-01: *Enhance E-Mail and Web Security*, ensuring: SSLv2 and SSLv3 are disabled on web servers; DES and RC4 ciphers are disabled on web servers; a list is provided to FS/USDA, identifying for DHS the agency second-level domains that can be HSTS preloaded, for which HTTPS will be enforced for all sub-domains.

5.18.4 The contractor shall enable SMTP for all e-mail applications, in accordance with OMB Memoranda M-17-06, M-15-13, M-08-23, M-10-23; CISA BOD 18-01; and NIST SP 800-52 and SP 800-44.

5.18.5 The contractor shall abide by FS/USDA guidelines concerning auto-forwarding of department email to non-Department accounts by not configuring email accounts to auto-forward to non-usda.gov email addresses.

5.18.6 Public-Facing Websites. If an official public-facing website will be developed, modified, or maintained, then:

5.18.6.1 In accordance with OMB M-17-06, for requirements involving web applications, web servers, and web services, the contractor shall follow the policies, principles, standards, and guidelines on information security and privacy, in accordance with FISMA, and implement security and privacy requirements as set forth in OMB Circular A-130 and current, final version of NIST Special Publication 800-44, *Guidelines on Securing Public Web Servers*.

5.18.6.2 The contractor use of third-party websites and applications shall comply with all relevant privacy protection requirements and a careful analysis of privacy implications as specified in OMB Memorandum M-10-23, *Guidance for Agency Use of Third-Party Websites*.

5.18.6.3 Prior to its posting information on public websites, the contractor will ensure that the approval and clearance of publicly accessible information has been completed by the appropriate FS officials in accordance with FS policy and procedures.

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

5.18.7 **Non-Public Facing Websites.** The contractor shall implement capabilities for all inbound network traffic to pass through a web content filter, which provides anti-phishing, anti-malware, and blocking of malicious websites (e.g., fake software updates, fake antivirus offers, and phishing offers).

5.19. **Scanning Desktops Laptops and Other Computing Devices.** The contractor shall ensure that all IT equipment (e.g., laptops, desktops, servers, routers, mobile devices, peripheral devices, etc.) used to process information on behalf of FS are deployed and operated in accordance with automated configuration settings and configuration management in accordance with FS/USDA security policies, including but not limited to:

5.19.1 Configuring its systems to allow for periodic FS/USDA vulnerability and security configuration assessment scanning.

5.19.2 Using Security Content Automation Protocol (SCAP)-validated tools with USGCB Scanner capabilities to scan its systems at least on a monthly basis and report the results of these scans to the CO and/or COR, Project Officer, and any other applicable designated Points of Contact (POC).

6.0 SECURITY OF HARDWARE OR SOFTWARE PRODUCTS

6.1 By accepting this contract/agreement, the Contractor and other external organizations (hereafter called Contractor) providing Information Technology (IT) resources or services to the United States Forest Service (FS) agrees to comply with the applicable IT security policy as outlined in this document.

6.2 The substance of this entire section shall be included in all subcontracts under this contract.

6.3 The contractor shall comply with all security-related Federal Acquisition Regulation (FAR) clauses incorporated by the Contracting Officer (CO) in other parts of the solicitation.

6.4 Definitions.

- **Hardware.** The material physical components of a system (see NIST SP 800-53 Rev5). Examples include, but are not limited to, laptops, desktops, servers, routers, mobile devices, peripheral devices, etc.
- **Software.** The term “software” for purposes of this section includes firmware, operating systems, applications, and application services (e.g., cloud-based software), as well as products containing software (see OMB M-22-18).

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

6.5 Encryption. The contractor shall:

6.5.1 Verify that the encryption solutions in use have been validated under the Cryptographic Module Validation Program to confirm compliance with FIPS 140-3. The contractor shall provide a written copy of the validation documentation to the COR when required by the Program Office.

6.5.2 Use the Key Management system on the USDA personal identification verification (PIV) card or establish and use a key recovery mechanism to ensure the ability for authorized personnel to encrypt/decrypt information and recover encryption keys. Encryption keys shall be provided to the CO, COR, or to the Project Manager or Program Manager, upon request and at the conclusion of the contract.

6.6 Cyber Supply Chain Security.

6.6.1 Cyber Supply Chain Risk Management Requirements. The Contractor shall comply with *USDA Cyber Supply Chain Risk Management (C-SCRM) Contract Language* (included in Section 9 of this Appendix).

6.6.2 Notification of Supply Chain Compromises. The Contractor shall develop, propose, and implement procedures for notifying the CO, as well as FS/USDA Cybersecurity personnel, or other Forest Service personnel of any compromises of its supply chain (in accordance with the *USDA Cyber Supply Chain Risk Management (C-SCRM) Contract Language*). Such procedures are subject to approval by the CO prior to implementation. [SR-08]

6.6.3 Data, Documentation, Tools, Or System Components Disposal. The Contractor shall ensure any data, documentation, tools, or system components containing controlled unclassified information (CUI) or other non-publicly-available information is properly sanitized using the processes specified in NIST SP-800-88 Rev. 1, *Guidelines for Media Sanitization*, prior to disposal.

6.6.4 Maintaining Configuration Control of Components Awaiting Service or Repair. The Contractor shall ensure that all system components awaiting service or repair, and the serviced or repaired components awaiting return to service, are maintained under configuration control.

6.7 Foreign Sourcing

6.7.1. The Contractor will comply with all requirements related to “Country of Origin” in the *USDA Cyber Supply Chain Risk Management (C-SCRM) Contract Language* (see Section 9 of this Appendix). This includes the provision that the Contractor shall not use any product or its components (including hardware, software, and firmware) that are on the Department of Commerce Entity List, including countries where the development, manufacturing, maintenance, and service for the product are provided.

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

6.7.2. The Contractor shall comply with any FAR provisions included by the Contracting Officer concerning the use/acquisition of products or services from prohibited entities/sources.

6.8. USDA Office of Contracts & Procurement (OCP) Contract Requirements for Secure Software Development Attestation Forms. In support of OMB memos [M-22-18](#) and [M-23-16](#), attestation forms are required to be completed for all “software that is provided by software producers” in order to “attest to complying with Government-specified minimum secure software development practices.”

6.8.1. The Contractor shall provide completed Attestation Forms for all software components delivered under this contract. This requirement applies to both custom-developed software and third-party software integrated into the final deliverables. The Contractor must submit the completed Attestation Forms at the following milestones:

6.8.1.1 Prior to contract award.

6.8.1.2 With each major software update or release.

6.8.1.3 Upon request by the Contracting Officer.

6.8.2. The Contractor must submit the attestation to all of the following:

6.8.2.1 Online at <https://softwaresecurity.cisa.gov/software> and associate USDA with the submittal.

6.8.2.2 And send an email to FY24VendorAttestations@usda.gov with the signed attestation form with a copy (cc) to the CO when complete.

6.8.3 The Contractor is responsible for ensuring the accuracy and completeness of the Software Attestation Forms. Any discrepancies or issues identified in the attestation must be promptly addressed and resolved by the Contractor at no additional cost to the Government. The Government reserves the right to validate the submitted Software Attestation Forms and request additional documentation or evidence to verify compliance. The Contractor shall cooperate fully and provide any requested information within ten (10) business days of the request. Failure to submit the completed Software Attestation Forms in accordance with the requirements outlined herein may result in failure to receive a contract, withholding of payments, termination of the contract for default, or other remedies as deemed appropriate by the Government.

6.9 Vulnerability Identification and Remediation.

6.9.1 The contractor shall remediate security risks for which they are responsible, including

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

those identified during their own development, included third party open-source software packages, scanning and testing activities, as well as those identified during testing, A&A and continuous monitoring activities by the government or its designated representatives. The Contractor shall report vulnerabilities identified in any component through scans or other methods. The FS shall determine the risk rating of all identified vulnerabilities.

6.9.2 In providing the products and services described in this Agreement the Contractor shall provide, at no additional cost to the government, appropriate software and firmware updates to remediate newly discovered vulnerabilities or weaknesses within the prescribed timelines: Critical vulnerabilities shall be remediated within 14 days from discovery; and all High, Medium, and Low vulnerabilities shall be mitigated within 30 days from discovery. A shorter timeframe may be required by CISA in a Binding Operational Directive or Emergency Directive. In the event that a specific vulnerability or other risk finding cannot be remediated within the prescribed timelines above, variance from the timeline must be approved by FS in accordance with the USDA Plan of Action and Milestones (POA&M) Standard Operating Procedures (SOP), and shall be added to the designated POA&M and remediated within the newly designated timelines specified by the Program Office.

7.0 SECURITY OF PRODUCTS OR SERVICES UTILIZING INTERNET OF THINGS (IoT) TECHNOLOGY OR OPERATIONAL TECHNOLOGY (OT)

7.1. The substance of this entire section shall be included in all subcontracts under this contract.

7.2. Definitions and General Requirements for IoT and OT.

7.2.1 Definitions. NIST defines Internet of Things (IoT) devices as those that have at least one transducer (sensor or actuator) for interacting directly with the physical world and at least one network interface (e.g., Ethernet, WiFi, Bluetooth) for interfacing with the digital world. Many IoT devices constitute Operational Technology (OT), defined by NIST as “[p]rogrammable systems or devices that interact with the physical environment (or manage devices that interact with the physical environment). These systems/devices detect or cause a direct change through the monitoring and/or control of devices, processes, and events. Examples include industrial control systems, building management systems, fire control systems, and physical access control mechanisms.”

7.2.2 General Requirements for IoT and OT. The Contractor shall:



INFORMATION TECHNOLOGY PROCEDURE

SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES

Version: 7.2A

7.2.2.1 Ensure that any IoT or OT devices, systems, or solutions provided under this contract comply with federal cybersecurity standards and guidelines, including NIST SP 800-82, *Guide to Operational Technology (OT) Security*, SP 800-213, *IoT Device Cybersecurity Guidance for the Federal Government: Establishing IoT Device Cybersecurity Requirements* and SP 800-213A, *IoT Device Cybersecurity Guidance for the Federal Government: IoT Device Cybersecurity Requirement Catalog*.

7.2.2.2 Implement robust security measures to protect against unauthorized access, data breaches, and other cybersecurity threats. This includes but is not limited to encryption, access controls, regular security assessments, and compliance with applicable federal laws and regulations related to information security.

7.2.2.3 Promptly report any security incidents or breaches to the Contracting Officer and take corrective action(s) as required.

7.3 To comply with inventory requirements of the IoT Cybersecurity Act and OMB Memo M-25-04, the contractor will provide the following information on all IoT/OT devices provided or used under this contract:

7.3.1 Asset Identification: All devices and systems that meet the provided definition of covered IoT assets.

7.3.2 Asset Description: Including make, model and any relevant specifications or configurations. Each asset should have a unique identifier, such as a serial or asset tag, to distinguish it from other assets.

7.3.3 Asset Categorization: The device's function.

7.3.4 Vendor/Manufacturer Information: Details about the vendor or manufacturer (e.g., contact information and support channels.)

7.3.5 Software and Firmware Versions: Where available, record the installed software and firmware versions, including relevant patches or updates applied to the asset.

7.3.6 Network Connectivity, Integrations and API Information: Include any static IP addresses and interconnective communication with other devices (e.g., uncommon ports, protocols).

7.3.7 Security Controls: Describe alignment to requirements and controls, such as NIST SP 800-213 and 213A, SP 800-82, SP 800-53, and other standards and protocols.

7.4. The contractor shall only connect OT implemented under this contract using USDA Non-Enterprise Agency Dedicated Internet (ADI) connections. The contractor shall, in coordination with the CO and supported program manager, coordinate with the FS IT Integration Service Branch requirements (Telecomm Services Delivery) to establish authorized connections via ADI.

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

7.5. When the contractor will use, design, host, implement, or interconnect an external information system to control OT in any FS environment under this contract, the Contractor shall:

7.5.1. Prior to connecting to any FS/USDA environment, or processing any data from or on behalf of FS/USDA, receive an Authorization to Operate (ATO) for their external information system, in accordance with USDA/FS regulations and policies;

7.5.2 Prior to connecting to any FS/USDA environment, or processing any data from or on behalf of FS/USDA, receive approval for all remote access, in accordance with USDA/FS regulations and policies.

SECTION 8.0 SECURITY OF LAND MOBILE RADIO-RELATED HARDWARE OR SOFTWARE

8.1 By accepting this contract/agreement, the Contractor and other external organizations (hereafter called Contractor) providing Information Technology (IT) resources or services to the United States Forest Service (FS) agrees to comply with the applicable IT security policy as outlined in this document.

8.2 The substance of this entire section shall be included in all subcontracts under this contract.

8.3 This section only applies to radios (hand-held or vehicle-mounted) their related ancillary hardware, and software associated with both.

8.4 **Definitions.** For the purposes of this section, the following apply:

- “Ancillary hardware” generally includes such items as components for radio control, testing, power systems or transmission systems.
- Hardware. The material physical components of a system (see NIST SP 800-53 Rev5). Examples include, but are not limited to, laptops, desktops, servers, routers, mobile devices, peripheral devices, etc., and radios.
- Software. The term “software” for purposes of this section includes firmware, operating systems, applications, and application services (e.g., cloud-based software), as well as products containing software (see OMB M-22-18).

8.5 **Encryption.** When encryption capability is required by FS in accordance with the technical specifications, bill of materials or other acquisition requirements documentation included in this contract, the contractor shall:

8.5.1 Verify that the encryption solutions provided have been validated under the Cryptographic Module Validation Program to confirm compliance with FIPS 140-3. The contractor shall provide a written copy of the validation documentation to the COR when required by the Program Office.

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

8.5.2 Ensure the solution provides for encryption key management by authorized *government* personnel, allowing them the ability to create, distribute, use, archive, recover and destroy encryption keys as required by mission and policy needs.

8.6 Cyber Supply Chain Security.

8.6.1 Cyber Supply Chain Risk Management Requirements. The Contractor shall comply with *USDA Cyber Supply Chain Risk Management (C-SCRM) Contract Language* (included in Section 9 of this appendix).

8.6.2 Notification of Supply Chain Compromises. The Contractor shall develop, propose, and implement procedures for notifying the, as well as FS/USDA Cybersecurity personnel, of any compromises of its supply chain (in accordance with the *USDA Cyber Supply Chain Risk Management (C-SCRM) Contract Language*). Such procedures are subject to approval by the CO prior to implementation. [SR-08]

8.6.3 Data, Documentation, Tools, Or System Components Disposal. The Contractor shall ensure any data, documentation, tools, or system components containing controlled unclassified information (CUI) or other non-publicly-available information is properly sanitized using the processes specified in NIST SP-800-88 Rev. 1, *Guidelines for Media Sanitization*, prior to disposal.

8.6.4 Maintaining Configuration Control of Components Awaiting Service or Repair. The Contractor shall ensure that all system components awaiting service or repair, and the serviced or repaired components awaiting return to service, are maintained under configuration control.

8.7 Foreign Sourcing.

8.7.1. The Contractor will comply with all requirements related to “Country of Origin” in the *USDA Cyber Supply Chain Risk Management (C-SCRM) Contract Language* (included in Section 9 of this appendix). This includes the provision that the Contractor shall not use any product or its components (including hardware, software, and firmware) that are on the Department of Commerce Entity List, including countries where the development, manufacturing, maintenance, and service for the product are provided.

8.7.2. The Contractor shall comply with the any FAR provisions included by the Contracting Officer concerning the use/acquisition of products or services from prohibited entities/sources.

8.8. **USDA Office of Contracts & Procurement (OCP) Contract Requirements for Secure Software Development Attestation Forms.** In support of OMB memos [M-22-18](#) and [M-23-16](#), attestation forms are required to be completed for all “software that is provided by software producers” in order to “attest to complying with Government-specified minimum secure software development practices.”

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

8.8.1. The Contractor shall provide completed Attestation Forms for all software components delivered under this contract. This requirement applies to both custom-developed software and third-party software integrated into the final deliverables. The Contractor must submit the completed Attestation Forms at the following milestones:

- 8.8.1.1 Prior to contract award.
- 8.8.1.2 With each major software update or release.
- 8.8.1.3 Upon request by the Contracting Officer.

8.8.2. The Contractor must submit the attestation to all of the following:

- 8.8.2.1 Online at <https://softwaresecurity.cisa.gov/software> and associate USDA with the submittal.
- 8.8.2.2 And send an email to FY24VendorAttestations@usda.gov with the signed attestation form with a copy (cc) to the CO when complete.

8.8.3 The Contractor is responsible for ensuring the accuracy and completeness of the Software Attestation Forms. Any discrepancies or issues identified in the attestation must be promptly addressed and resolved by the Contractor at no additional cost to the Government. The Government reserves the right to validate the submitted Software Attestation Forms and request additional documentation or evidence to verify compliance. The Contractor shall cooperate fully and provide any requested information within ten (10) business days of the request. Failure to submit the completed Software Attestation Forms in accordance with the requirements outlined herein may result in failure to receive a contract, withholding of payments, termination of the contract for default, or other remedies as deemed appropriate by the Government.

8.9 Vulnerability Identification and Remediation.

8.9.1 The contractor shall remediate security risks for which they are responsible, including those identified during their own development, included third party open-source software packages, scanning and testing activities, as well as those identified during testing, A&A and continuous monitoring activities by the government or its designated representatives. The Contractor shall report vulnerabilities identified in any component through scans or other methods. The FS shall determine the risk rating of all identified vulnerabilities.

8.9.2 In providing the products and services described in this Agreement the Contractor shall provide, at no additional cost to the government, appropriate software and firmware updates to

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

remediate newly discovered vulnerabilities or weaknesses within the prescribed timelines: Critical vulnerabilities shall be remediated within 14 days from discovery; and all High, Medium, and Low vulnerabilities shall be mitigated within 30 days from discovery. A shorter timeframe may be required by CISA in a Binding Operational Directive or Emergency Directive. In the event that a specific vulnerability or other risk finding cannot be remediated within the prescribed timelines above, variance from the timeline must be approved by FS in accordance with the USDA Plan of Action and Milestones (POA&M) Standard Operating Procedures (SOP), and shall be added to the designated POA&M and remediated within the newly designated timelines specified by the Program Office.

9.0 CYBER SUPPLY CHAIN RISK MANAGEMENT REQUIREMENTS

1. This section includes the entire *USDA Cyber Supply Chain Risk Management (C-SCRM) Contract Language* document.
2. The *USDA Cyber Supply Chain Risk Management (C-SCRM) Contract Language* contains several entries (highlighted in yellow) that require quantification. The references below provide the text for the Contractor to use in those instances:
 - a. Paragraph 1.2: The USDA SCRM Strategy is **not a publicly releasable document, there is no link available.**
 - b. Paragraph 2.d): "...notification shall occur **14 business days** prior to initiating a change in the list of countries."
 - c. Paragraph 4.3.1: "...e-mail to the Contracting Officer, Program Manager, and COR within **60 minutes** of discovery."
 - d. Paragraph 5.3.1: "...notify USDA **within no more than 60 minutes of discovery** by telephone and email..."
 - e. Paragraph 5.3.2: "Within **3 days** of notifying USDA of the security incident..."
 - f. Paragraph 5.3.4: "Within **14 days** of a security incident..."

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

USDA Cyber Supply Chain Risk Management (C-SCRM) Contract Language

Version 1.0

Approved: Nov 04, 2020

Document Control Information

Version #	Author	Revision Date	Approval Date	Description of change
1.0	ISC SMD	10/28/2020	11/04/2020	Initial Document

The information contained herein is property of USDA OCIO. Unauthorized reproduction or disclosure of this information in whole or in part is prohibited. Limit distribution accordingly.

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

Table of Contents

1	USDA CYBER SUPPLY CHAIN RISK MANAGEMENT (C-SCRM)	4
1.1	USDA SCRM Policy	4
1.2	USDA Supply Chain Risk Review Team	5
1.3	C-SCRM Methodology	5
2	COUNTRY OF ORIGIN (COO)	6
3	PERSONNEL AND CERTIFICATION REQUIREMENTS	7
3.1	Personnel.....	7
3.2	Cybersecurity Certification and Training	9
4	INFORMATION AND COMMUNICATIONS TECHNOLOGY (ICT) SUPPLY CHAIN RISK MANAGEMENT (SCRM) SOFTWARE DEVELOPMENT LIFECYCLE (SDLC)	10
4.1	Continuous Diagnostic and Mitigation (CDM) Approved Products List (APL) Supply Chain Risk Management Plan	11
4.2	SCRM Plan Submittal and Review	12
4.3	Manufacturing (Original Equipment Manufacturer (OEM))	13
4.4	End of Life/Support Products	13
4.5	Transport/Shipping.....	16
4.6	Pre-Deployment	16
4.7	Deployment.....	16
4.8	Operation and Maintenance	16
4.9	Return USDA Government Furnished Property.....	17
5	ALL-INCLUSIVE AREAS WITHIN ICT SCRM SDLC	17
5.1	Chain of Custody	17
5.2	Tamper Resistance and Detection.....	18
5.3	Incidents	18
5.4	Vulnerabilities.....	19
5.5	USDA's Audit Rights.....	20
5.6	Covered Telecommunication Equipment or Services (Section 889(a)(1)(B)).....	20
5.7	Environmental Risks	21
6	APPENDICES.....	22

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

6.1	[Contractor/Sub-Contractor] Cybersecurity Policy / System Security Plan	22
6.2	Cybersecurity & Supply Chain Risk Management (SCRM) References	22
6.3	DEFINITIONS	24
6.4	Acronyms and Abbreviations.....	26

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

1 USDA CYBER SUPPLY CHAIN RISK MANAGEMENT (C-SCRM)

Cyber Supply Chain Risk Management (C-SCRM) is the process of taking strategic steps to identify, assess and mitigate supply chain risk to departmental and agency information systems, system components and associated services based on analysis of the criticality of system components, services and functions. It covers the entire life cycle of a system (including design, development, distribution, deployment, acquisition, maintenance, and destruction) as supply chain threats and vulnerabilities may intentionally or unintentionally compromise information technology (IT) systems with operational technology (OT) systems (IT/OT) product or service at any stage.

IMPORTANT:

- **Program offices/CORs shall ensure the appropriate Cybersecurity SCRM language is included in requirements documents (PWS, SOW, SOO) and incorporated into the resultant contract action.**
- **The content of this document is applicable to IT or security related contracts.**

C-SCRM contract language is in support the latest publication of:

- [USDA DR 3540-003](#) – *USDA Security Assessment and Authorization (A&A) Policy*,
- [Federal Acquisition Supply Chain Security Act 2018](#),
- [NIST SP 800-161](#) - *Supply Chain Risk Management Practices for Federal Information Systems and Organizations*,
- [NIST SP 800-37](#) - *Risk Management Framework for Information Systems and Organizations*,
- [NIST Cyber Supply Change Risk Management Program](#),
- [NIST SP 800-39](#), *Managing Information Security Risk and*,
- [NIST 800-88](#) - *Guidelines for Media Sanitization*.

1.1 USDA SCRM Policy

In line with its federal obligations, the United States Department of Agriculture (USDA) commits itself through the IT Security Strategy and the Information Security Program (SSISP) Policy (in draft) to develop a Supply Chain Risk Management (SCRM) capability to address supply chain risk. USDA SCRM strategy is based on external and organizational requirements and constraints (e.g., applicable laws and regulations). Policies include the purpose and applicability, as well as investment and funding requirements, of any SCRM program.

Based on the USDA supply chain policy, the SCRM identifies:

- Mission/business requirements that will influence SCRM, such as cost, schedule, performance, security, privacy, quality, and safety;
- Information security requirements, including SCRM-specific requirements;

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

- Organization-wide mission/business functions and how SCRM will be integrated into their processes;
- Risk tolerance level for supply chain risks;
- A group of individuals across the USDA organization who will address SCRM throughout the organization, known as the USDA SCRM Team; and
- Ensure that SCRM is appropriately integrated into the organization risk management policies and activities.

1.2 USDA Supply Chain Risk Review Team

Implementing SCRM requires organizations establish a coordinated team-based approach to assess supply chain risk and manage this risk by using programmatic and technical mitigation techniques. The coordinated team approach will enable agencies to conduct a comprehensive analysis of their supply chain, communicate with external partners/stakeholders, and gain broad consensus regarding appropriate resources for SCRM. Details of SCRM Review Team roles and responsibilities are contained in USDA's SCRM Strategy document [\[Link\]](#).

The SCRM Review Team should consist of members with diverse roles and responsibilities for leading and supporting SCRM activities including information technology, information security, contracting, risk executive, mission/business, legal, supply chain and logistics, acquisition and procurement, and other relevant functions. These individuals may include government personnel or prime [Contractors/Sub-Contractors] hired to provide acquisition services to a government client. Members of the SCRM Review team should be a diverse group of people who are involved in the various aspects of the Software Development Lifecycle (SDLC). Collectively, to aid in SCRM, these individuals should have an awareness of, and provide expertise in organizational acquisition processes, legal practices, vulnerabilities, threats, and attack vectors, as well as an understanding of the technical aspects and dependencies of systems. The USDA Supply Chain Team may be an extension of an organization's existing information system risk management or include parts of a general risk management team.

1.3 C-SCRM Methodology

The C-SCRM methodology implements strategies to manage both every day and exceptional risks along the supply chain based on continuous risk assessment with the objective of reducing vulnerability and ensuring continuity. The below sections outline USDA's C-SCRM methodology.

Section 2: Country of Origin (COO) represents the country or countries of manufacture, production, design, or brand origin

Section 3: Personnel and Certification Requirements

- Personnel
- Certification and Training

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

Section 4: Information and Communications Technology (ICT) Supply Chain Risk Management (SCRM) Software Development Lifecycle (SDLC) phases:

- Manufacturing (Original Equipment Manufacturer)
- Transport/Shipping
- Pre-Deployment
- Deployment
- Operation and Maintenance
- Disposition/Return of Government Furnished Property

Section 5: All-Inclusive Areas within the ICT SCRM SDLC:

- Chain of Custody
- Anti-Tampering
- Identified Incidents
- USDA Audit Rights

2 COUNTRY OF ORIGIN (COO)

Country of Origin (COO) represents the country or countries of manufacture, production, design, or brand origin. The expectation is: (1) the cargo is what it purports to be and in the quantity stated; (2) the cargo was in the continuous possession or control by the carrier who took charge of the cargo from the time it was loaded in the container at origin until the time it is delivered at final destination; and (3) there is evidence of the identify of each person or entity who had access to it during its movement and that the cargo remained in the same condition from the moment it was sealed in the container for transfer to the carrier who controlled possession until the moment that carrier released the cargo into the receipted custody of another.

Country of Origin guidelines are as follows:

- a) USDA will not use any product or its components (including hardware, software, and firmware) that are on the *Department of Commerce Entity List*. This includes countries where the development, manufacturing, maintenance, and service for the product are provided.
- b) [Contractor/Sub-Contractor] shall identify the country (or countries) of origin of the procured product and its components (including hardware, software, and firmware).
- c) [Contractor/Sub-Contractor] will identify the countries where the development, manufacturing, maintenance, and service for the product are provided.

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

- d) [Contractor/Sub-Contractor] will notify USDA of changes in the list of countries where product maintenance or other services are provided in support of the procured product. This notification shall occur # days prior to initiating a change in the list of countries.
- e) [Contractor/Sub-Contractor] shall ensure that all-source threat and vulnerability information includes any available foreign ownership and control (FOCI) data. This data should be reviewed periodically as mergers and acquisitions, if affecting a supplier, may impact both threat and vulnerability information and therefore SCRM.
- f) [Contractor/Sub-Contractor] shall use trusted channels to ship procured products, such as U.S. registered mail.
- g) [Contractor/Sub-Contractor] shall demonstrate a capability for detecting unauthorized access throughout the delivery processes.
- h) [Contractor/Sub-Contractor] shall demonstrate chain-of-custody documentation for procured products as determined by USDA in its sole discretion and require tamper-evident packaging for the delivery of this product.
- i) [Contractor/Sub-Contractor] shall implement anti-tamper technologies and techniques that provide a level of protection for critical information systems, system components, and information technology products against known related threats including modification, reverse engineering, and substitution.

3 PERSONNEL AND CERTIFICATION REQUIREMENTS

3.1 Personnel

3.1.1 Background Check

As part of the [Homeland Security Presidential Directive \(HSPD\) 12](#), *Homeland Security Presidential Directive 12: Policy for a Common Identification Standard for Federal Employees and Contractors*, each [Contractor/Sub-Contractor] must provide identity documentation, as set forth in the Form (I-9), and the validity of the documentation is certified by at least three other checks incorporated into the ID-Proofing process.

- a) [Contractor/Sub-Contractor] shall comply with the personal identity verification (PIV) policies and procedures established by the Department of Agriculture (USDA) [Directives 4620-002](#) series - *Common Identification Standard for U.S. Department of Agriculture Employees and Contractors*.
- b) Should the results of the PIV process require the exclusion of a [Contractor/Sub-Contractor]'s employee; the Contracting Officer Representative (COR) shall notify the Contracting Officer (CO) in writing.
- c) The [Contractor/Sub-Contractor] must appoint a representative to manage compliance with the PIV policies established by the USDA Directives 4620-002 series and to maintain a list of

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

- employees eligible for a USDA LincPass required for performance of the work.
- d) The responsibility of maintaining a sufficient workforce remains with the [Contractor/Sub-Contractor]. Employees may be barred by the Government from performance of work should they be found ineligible or to have lost eligibility for a USDA LincPass. Failure to maintain a sufficient workforce of employees eligible for a USDA LincPass may be grounds for termination of the contract.
 - e) The [Contractor/Sub-Contractor] shall insert this clause in all subcontracts when the sub[Contractor/Sub-Contractor] is required to have routine physical access to a federally controlled facility and/or routine access to a federally controlled information system.
 - f) The PIV Sponsor for this contract is a designated program point of contact, which in most cases is the COR, unless otherwise specified in this contract.

In addition to meeting the requirements of HSPD-12 for PIV (I and II process), all [Contractor/Sub-Contractor]s requiring routine physical access for Federally-controlled facilities and/or routine access to Federally-controlled information systems must have been successfully identity proofed and successfully adjudicated National Agency Check with Written Inquiries (NACI) or Office of Personnel Management (OPM)/National Security (NS) community background investigation to serve on a USDA contract. Contract personnel must have a minimum of a NACI or higher level of background investigation depending on the Position Sensitivity Designation (PSD).

3.1.2 Position Sensitivity Designations (PSDs)

All positions within USDA are assigned Position Sensitivity Designations (PSDs) based upon the risk/damage an unauthorized disclosure would cause to the Agency and/or National Security. This includes positions occupied by [Contractors/Sub-Contractors]. The Contracting Officer (CO) and/or Contracting Officer Representative (COR) will identify and assign a Position Sensitivity Designation Code to each position that will be occupied by a [Contractor/Sub-Contractor] in the performance of the contract. The CO/COR will advise the [Contractor/Sub-Contractor] of the assigned designation and investigative requirements at the offset of contract talks. The minimum Public Sector Information (PSI) for a [Contractor/Sub-Contractor] is National Agency Check with Law Enforcement and Credit Check (NACLC). However, based upon the assigned sensitivity code, the minimum level PSI may not meet the requirements and a higher level of investigation and/or Security Clearance may be required. The Contracting Officer Representative (COR) will submit all investigative and/or clearance data to the Physical Security Team (PST) five (5) days prior to the [Contractor/Sub-Contractor]'s first day of work. The PSDs are separated into two categories, Public Trust Positions (Risk) and National Security Positions.

- a) Public Trust Positions: These positions are identified as Low Risk, Moderate Risk, and High Risk. They are numerically identified as 1, 5, and 6, respectively. Each of these designations requires a different PSI and

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

a favorable Suitability Determination. Public Trust Positions do not require Personnel Security Clearances.

- b) National Security Positions: These positions are identified as Non-Critical Sensitive, Critical Sensitive and Special Sensitive. They are numerically identified as 2, 3 and 4, respectively. Each of these designations requires a different PSI and a favorable Security Determination. National Security Positions require a Personnel Security Clearance equal to or higher than the level of Access required performing the duties. The level of Clearance is requested at the time the PSI is submitted.

For Position Sensitivity Designation (PSD) for Contract Employees, the [Contractor/Sub-Contractor] will submit proof of their contract employee’s investigative and/or clearance data to the COR five (5) days prior to the [Contractor/Sub-Contractor]’s first day of work.

Only appropriately cleared [Contractors/Sub-Contractors] will be utilized in the performance of this Contract. The Physical Security Team will review all investigated and clearance data submitted by the [Contractor/Sub-Contractor] on behalf of their employees and determine its validity. Should any contract employee be removed for security or suitability reasons, it is incumbent on the Company to provide a replacement that meets or exceeds all PSI and/or Clearance requirements. Any failure of the [Contractor/Sub-Contractor] to comply with the Personnel Security requirements may result in the termination of the [Contractor/Sub-Contractor] and/or Contract for default/cause.

[Contractor/Sub-Contractor] ID credentials will be issued after successful identity proofing of the [Contractor/Sub-Contractor] employee applicant and upon verification of a successfully adjudicated NACI or OPM/NS BI.

For more information about HSPD-12, see <https://hspd12.usda.gov/>.

3.1.3 [Contractor/Sub-Contractor] System Access

The Contracting Officer or Contracting Officer’s Representative will work with the project manager and/or supervisor to determine the appropriate security access required by the Contractor. USDA will ensure access is commensurable with the functions to be performed by utilizing the RBAC (Role-Based Access Concept).

3.1.4 Non-Disclosure Agreement

All [Contractor/Sub-Contractor] and sub[Contractor/Sub-Contractor] cybersecurity personnel must submit a Non-Disclosure Agreement, “Employee/[Contractor/Sub-Contractor] Non-Disclosure Agreement” form, prior to the commencement of any cybersecurity work on the contract. Further, [Contractor/Sub-Contractor] and sub[Contractor/Sub-Contractor] personnel must submit a Non- Disclosure agreement whenever replacement personnel are proposed. Any information provided by the [Contractor/Sub-Contractor] or sub[Contractor/Sub-Contractor] in the performance of this contract or obtained by the government is only

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

to be used in the performance of this contract.

3.1.5 [Contractor/Sub-Contractor] Termination / Resignation

Upon termination, resignation or other event leading to a contract employee leaving duty under this contract, the contract employee is responsible for returning all Government identification, vehicle passes, other Government property or anything considered Government Furnished issued to the employee. Such material shall be returned to the Contracting Officer's Representative. Failure on the part of the employee to return such property may result in the [Contractor/Sub-Contractor]'s liability for all costs associated with correcting the resultant breach in building security. Refer to FAR for specific details.'

3.2 Cybersecurity Certification and Training

3.2.1 Computing Environment (CE) Certification

The computing environment involves the collection of computer machinery, data storage devices, workstations, software applications, and networks that support the processing and exchange of electronic information demanded by the software solution. The various types of CE include Personal, Time Sharing, Client Server, Distributed, Cloud and Cluster. Therefore, [Contractor/Sub- Contractor] shall have the required certification for the computing environment.

3.2.2 Cybersecurity Maturity Model Certification (CMMC)

USDA SCRM Strategy applies to systems operated by USDA and entities not under the jurisdiction of the USDA Secretary that are employed or contracted to process, transmit, or store USDA information through services such as (but not limited to), platform as a service (PaaS), infrastructure as a service (IaaS), and software as a service (SaaS). In accordance with [USDA DR 3540-003](#), The Contracting Officer Representative/Program Manager will certify that [Contractor/Sub-Contractor] has the appropriate DOD Cybersecurity Maturity Model Certification (CMMC) level as prescribed by USDA and outlined below.



INFORMATION TECHNOLOGY PROCEDURE

SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES

Version: 7.2A



3.2.3 Information Security Awareness Training

The Contracting Officer Representative/Program Manager will certify that [Contractor/Sub- Contractor] personnel have completed the required Information Security Awareness and Rules of Behavior Training prior to submission of a Security Access Requests.

4 INFORMATION AND COMMUNICATIONS TECHNOLOGY (ICT) SUPPLY CHAIN RISK MANAGEMENT (SCRM) SOFTWARE DEVELOPMENT LIFECYCLE (SDLC)

Information and Communications Technology (ICT) Supply Chain Risk Management (SCRM) Software Development Lifecycle (SDLC) is implemented as part of overall risk management activities, such as those described in [NIST SP 800-39](#), *Managing Information Security Risk*. Activities should involve identifying and assessing applicable risks, determining appropriate mitigating actions, developing an ICT SCRM Plan to document selected mitigating actions, and monitoring performance against that Plan.

[Contractor/Sub-Contractor] shall ensure the latest publication of [NIST SP 800-161](#) - *Supply Chain Risk Management Practices for Federal Information Systems and Organizations* and [NIST SP 800-37](#) - *Risk Management Framework for Information Systems and Organizations* are incorporated into their ICT SCRM SDLC process.

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

Consistent with the latest publication of [NIST SP 800-161](#) and [NIST SP 800-37](#), the acquisition community at the USDA and agencies will adopt an ICT SCRM SDLC approach to managing risk to information systems. The USDA, agencies, and personnel will integrate SCRM processes, activities and tasks throughout the life cycle of agency systems, components and services.

4.1 Continuous Diagnostic and Mitigation (CDM) Approved Products List (APL) Supply Chain Risk Management Plan

The Continuous Diagnostics and Mitigation (CDM) Approved Products List (APL) Product Submission Instructions reference the requirement to submit a Supply Chain Risk Management Plan (SCRM) as part of that activity. The [CDM APL SCRM Plan](#) is in support of the National Institute of Standards (NIST) and the latest publication of NIST Special Publication (SP) 800-53 “SA-12” supply chain control. [Contractor/Sub-Contractor] is responsible for providing the CDM APL SCRM Plan. The purpose of this document is to provide background information on the SCRM requirement and outline the instructions an offeror is to follow in completing and submitting the CDM APL SCRM Plan. The CDM APL SCRM Plan consists of (1) the completed questionnaires and (2) additional information the offeror wishes to provide. APL submission packages that do not include completed CDM-APL-SCRM questionnaires will fail conformance. Additional information can be submitted; APL packages will not fail conformance for the lack of providing SCRM information beyond the questionnaires for CDM-APL-SCRM.

The objective of CDM SCRM Plan is to provide information to Agencies and ordering activities about how the offeror identifies, assesses, and mitigates supply chain risks in order to facilitate better informed decision-making by Agencies and ordering activities. The CDM SCRM Plan is intended to provide visibility into, and improve the buyer’s understanding of, how the Offeror’s proposed products are developed, integrated and deployed; as well as the processes, procedures, and practices used to assure the integrity, security, resilience, and quality of those products.

The contractor shall include a CDM SCRM Plan with its proposal that addresses counterfeit and illegally modified products. The CDM SCRM plan shall describe the contractor’s approach to SCRM and demonstrate how the contractor’s approach will reduce and mitigate supply chain risks. For additional details on GSA’s internal guidance on supply chain risk management, see subpart GSAM 504.70.

The contractor shall provide a CDM SCRM plan to manage supply chain risk throughout each of the five (5) supply chain phases specified in its proposal: 1) design and engineering, 2) manufacturing and assembly, 3) distribution and warehousing, 4) operations and support, and 5) disposal and return. In addition to the components and processes for which the contractor is directly responsible, and as feasible, the contractor shall identify “specified supporting infrastructure beyond the system boundary” and where appropriate, include such infrastructure in its SCRM Plan.

The CDM SCRM Plan shall address at a minimum, but not be limited to, the following:



INFORMATION TECHNOLOGY PROCEDURE

SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES

Version: 7.2A

1. How the contractor ensures that requirements for genuine Information Technology Tools (ITT) are imposed upon its direct suppliers, whether the direct supplier is a systems integrator, reseller or OEM. The requirements for assurance and supporting evidence must include:
 - a) The contractor performs reasonable steps to ensure its SCRM Plan is performed for ITT in its delivered and installed configuration;
 - b) Equipment resellers from whom the contractor purchases ITT have valid licenses for OEM equipment and software;
 - c) The ITT OEM exercises strict quality control to ensure that counterfeit or illegally modified hardware or software components are not incorporated into the OEM product; and
 - d) The contractor ensures traceability of assurance and evidence of genuineness of ITT back to the licensed product and component OEMs.
2. The contractor's use of system security engineering processes in specifying and designing a system that is protected against external threats and against hardware and software vulnerabilities.
3. The contractor's strategy for implementing SCRM security requirements throughout the life of the contract. The SCRM plan shall address the security controls described in the latest publication of [NIST SP 800-53](#). Implementation of the controls shall be tailored in scope to the effort and the specific information.
4. The criticality analysis (CA) process used by the contractor to determine Mission Critical Functions and the protection techniques (countermeasures and sub-countermeasures) used to achieve system protection and mission effectiveness. The CA shall describe the contractor's supply chain for all critical hardware and software components (and material included in products), key suppliers, and include proof of company ownership and location (on-shore or off-shore) for key suppliers and component manufacturers.
5. How the contractor will ensure that products and components are not repaired and shipped as new products and components are provided to the government.
6. How the contractor will ensure that supply channels are monitored for counterfeit products throughout the product life cycle to include maintenance and repair.
7. How the contractor's physical and logical delivery mechanisms will protect against unauthorized access, exposure of system components, information misuse, unauthorized modification, or redirection.
8. How the contractor's operational processes (during maintenance, upgrade, patching, element replacement, or other sustainment activities) and disposal processes will limit opportunities for knowledge exposure, data release, or system compromise.
9. Which of the following identifies the relationship between the contractor and the manufacturer:

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

1) OEM, 2) authorized reseller, 3) authorized partner/distributor, or 4) unknown/unidentified source.

10. How the contractor will ensure independent verification and validation of assurances, and provide supporting evidence as required.

[NIST SP 800-161](#) identifies supply chain risk management (SCRM) best practices. The offeror shall update its SCRM Plan to include any future changes to the NIST SCRM Guidelines and all such modifications to the Plan shall be made at no cost to the government.

4.2 SCRM Plan Submittal and Review

The plan shall be submitted with the contractor's proposal. Updates shall be submitted on an annual basis to the CO and COR. All information included will be treated as Controlled Unclassified Information (CUI) pursuant to Executive Order 13556, shared only with government agencies, and used solely for the purposes of mission-essential risk management. All reviews shall be completed within a 45-day time period.

4.3 Manufacturing (Original Equipment Manufacturer (OEM))

[Contractor/Sub-Contractor] developers shall perform industry best practices associated with security testing and evaluation consistent with the latest publication of [Special Publication 800-115 - Technical Guide to Information Security Testing and Assessment](#). This includes, but is not limited to, the following:

- Implement a repeatable and documented assessment methodology;
- Analyze findings, and develop risk mitigation techniques to address weaknesses;
- Provide consistency and structure to security testing, which can minimize testing risks; and
- Address resource constraints associated with security assessments.

4.3.1 Counterfeit Parts/Replacement Parts

A product is genuine if it is not counterfeited, imitated, tampered or adulterated and is not gray market, remanufactured, or refurbished. [Contractor/Sub-Contractor] shall report all suspected counterfeit material/items to the Government through the Government Industry Data Exchange Program (GIDEP) database and to the program office via e-mail to the Contracting Officer, Program Manager, and COR within # working days of discovery. The [Contractor/Sub-Contractor] shall prominently label all suspected counterfeit material/items and physically separate from all other supplies and shall not return or dispose suspected or confirmed counterfeit material/items to the supplier but hold such items for Government analysis and investigation. The [Contractor/Sub-Contractor] shall aid the Government investigation including providing all documents associated with the purchase, shipping, and other relevant data on the counterfeit materials/items. The Government will provide final disposition instructions for confirmed counterfeit material/items to include turnover to the Government.

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

4.4 End of Life/Support Products

Any product within 18 months of End of Life/End of Support will not be procured by USDA.

4.4.1 Product Integrity [GSA SECTION 846 – COUNTERFEIT ITEMS]

4.4.1.1 *Hardware, Software, and Patch Integrity and Authenticity:*

If [Contractor/Sub-Contractor] provides software or patches to USDA, [Contractor/Sub- Contractor] shall publish or provide a hash conforming to the Federal Information Processing Standard (FIPS) Security Requirements for Cryptographic Modules (FIPS 140-2) or similar standard information on the software and patches to enable USDA to use the hash value as a checksum to independently verify the integrity of the software and patches and avoid downloading the software or patches from [Contractor/Sub-Contractor]'s website that has been surreptitiously infected with a virus or otherwise corrupted without the knowledge of [Contractor/Sub-Contractor].

- a) [Contractor/Sub-Contractor] is responsible for providing software that is free of vulnerabilities by validating that those Common Vulnerability and Exposures (CVE), common weakness enumeration (CWE);
- b) Open Web Application Security Project (OWASP) items that are most dangerous to the mission are absent from the software and that the software operates at the least privilege required to complete its task; and
- c) [Contractor/Sub-Contractor] shall establish, document, and implement risk management practices for supply chain delivery of hardware, software (including patches), and firmware provided under this Agreement.

4.4.1.2 *Digital Delivery*

[Contractor/Sub-Contractor] shall specify how digital delivery for procured products (*e.g.*, software, applications, and data) including patches will be validated and monitored to ensure the digital delivery remains as specified. If USDA deems that it is warranted, [Contractor/Sub- Contractor] shall apply encryption to protect procured products throughout the delivery process.

4.4.1.3 *Firmware*

- a) Prior to the delivery of any products and services to USDA or any connection of electronic devices, assets or equipment to USDA's electronic equipment, [Contractor/Sub-Contractor] shall provide documentation regarding its patch management and vulnerability management and continuous monitoring (including third-party hardware, software, and firmware) for products, services, and any electronic device, asset, or equipment required to be connected to the assets of USDA during the provision of products and services under this Agreement. This documentation shall include information regarding:



INFORMATION TECHNOLOGY PROCEDURE

SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES

Version: 7.2A

- Resources and technical capabilities to sustain this program and process such as [Contractor/Sub-Contractor]'s method or recommendation for how the integrity of a patch is validated by USDA;
 - [Contractor/Sub-Contractor] procedures to Check Software and the patches for authenticity and integrity of the products with integrity verification tools, to detect unauthorized changes to software, information system and the supply chain. An example of a validation procedure may be the use of digital signature by an OEM to prove that the software delivered is from its originating source. When digital signatures are used for this purpose, the organization should ensure, when receiving such software, that the signed upgrade/download was not altered;
 - USDA will ensure that code authentication mechanisms such as digital signature, certificate is recognized and approved;
 - Implement the use of cryptographic mechanisms, to authenticate software, hardware, information systems within the supply chain infrastructure;
 - [Contractor/Sub-Contractor]'s approach and capability to remediate newly reported zero-day vulnerabilities; and
 - [Contractor/Sub-Contractor] shall ensure all developers are trained and held accountable for development of secure code.
- b) Unless otherwise approved by the USDA in writing, current or supported version of [Contractor/Sub-Contractor] products and services shall not require the use of out-of-date, unsupported, or end-of-life version of third-party components (*e.g.*, Java, Flash, Web browser, etc.).
- c) [Contractor/Sub-Contractor] shall verify and provide documentation that procured products (including third-party hardware, software, firmware, and services) have appropriate updates and patches installed prior to delivery to USDA.
- d) In providing the products and services described in this Agreement [Contractor/Sub-Contractor] shall provide appropriate software and firmware updates to remediate newly discovered vulnerabilities or weaknesses within [a negotiated time period]. Updates to remediate critical vulnerabilities shall be provided within a shorter period than other updates, within **14 days**. If updates cannot be made available by [Contractor/Sub-Contractor] within these time periods, [Contractor/Sub-Contractor] shall provide mitigations within a negotiated time period.
- e) When third-party hardware, software (including open-source software), and firmware is provided by [Contractor/Sub-Contractor] to USDA, [Contractor/Sub-Contractor] shall provide appropriate hardware, software, and firmware updates to remediate newly discovered vulnerabilities or weaknesses within [a negotiated time period]. Updates to remediate critical vulnerabilities shall be provided within a shorter period than other updates, within **14 days**. If these third-party updates cannot be made available by [Contractor/Sub-Contractor] within these time periods, [Contractor/Sub-Contractor] shall provide mitigations within a negotiated time period.

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

4.4.2 Viruses and Malware

[Contractor/Sub-Contractor] will use reasonable efforts to investigate whether computer viruses or malware is present in any software or patches before providing such software or patches to USDA.

- a) [Contractor/Sub-Contractor] warrants that it has no knowledge of any computer viruses or malware coded or introduced into any software or patches, and [Contractor/Sub-Contractor] will not insert any code which would have the effect of disabling or otherwise shutting down all or a portion of such software or damaging information or functionality.
- b) When installed files, scripts, firmware, or other [Contractor/Sub-Contractor] deliverer software solutions are flagged as malicious, infected, or suspicious by an anti-virus vendor through open source solutions, [Contractor/Sub-Contractor] must provide technical proof as to why the “false positive” hit has taken place to ensure their code’s supply chain has not been compromised.
- c) If a virus or other malware is found to have been coded or otherwise introduced as a result of [Contractor/Sub-Contractor]’s breach of its obligations under this Agreement, [Contractor/Sub-Contractor] shall immediately and at its own cost:
 - Take all necessary remedial action and provide assistance to USDA to eliminate the virus or other malware throughout USDA’s information networks, computer systems, and information systems, regardless of whether such systems or networks are operated by or on behalf of USDA; and
 - If the virus or other malware causes a loss of operational efficiency or any loss of data (A) where [Contractor/Sub-Contractor] is obligated under this Agreement to back up such data, take all steps necessary and provide all assistance required by USDA and its affiliates, and (B) where [Contractor/Sub-Contractor] is not obligated under this Agreement to back up such data, use commercially reasonable efforts, in each case to mitigate the loss of or damage to such data and to restore the efficiency of such data.

4.5 Transport/Shipping

4.5.1 Chain of Custody

Chain of Custody apply throughout the ICT SCRM SDLC phases; therefore, refer to [Section 5.1 – Chain of Custody](#).

4.5.2 Anti-Tamper Testing/Inspection

Tamper Resistance and Detection apply throughout the ICT SCRM SDLC phases; therefore, refer to [Section 5.2 – Anti-Tamper and Detection](#).

4.6 Pre-Deployment

4.6.1 Chain of Custody

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

Chain of Custody apply throughout the ICT SCRM SDLC phases; therefore, refer to [Section 5.1 – Chain of Custody](#).

4.6.2 Anti-Tamper Testing/Inspection

Tamper Resistance and Detection apply throughout the ICT SCRM SDLC phases; therefore, refer to [Section 5.2 – Anti-Tamper and Detection](#).

4.6.3 Scanning/Malicious code (Optical Media/SW/Scan Info Systems)

[Contractor/Sub-Contractor] will use reasonable efforts to investigate whether computer viruses or malware is present in any software or patches before providing such software or patches to USDA. Refer to [Section 4.2.2 - Viruses and Malware](#).

4.7 Deployment

4.7.1 System Configuration

[Contractor/Sub-Contractor] is responsible for system configuration (i.e. System hardening) and must be in compliance with the [USDA C2 level](#) of security (based on the NSA Trusted Computer Security Evaluation Criteria) for all USDA IT Systems. System hardening, or C2, as defined by the NSA, includes making specific modifications to an operating system before it is put into use in order to aid in the reduction of operating risks and to increase system availability, confidentiality and integrity. In addition [Contractor/Sub-Contractor] will comply to [DISA Security Technical Implementation Guide \(STIG\)](#).

4.8 Operation and Maintenance

4.8.1 Continuous Monitoring

[Contractor/Sub-Contractor] will provide ongoing agency system security, vulnerability, and threat awareness to USDA in accordance with Risk Management Framework (RMF) process. Continuous monitor and support agency IT system Authorization to Operate (ATO) submissions. Monitor IT network, information, and system security. [Contractor/Sub-Contractor]'s continuous monitoring practices shall be in compliance with [USDA DR 3505-005 - Cybersecurity Incident Management](#).

4.9 Return USDA Government Furnished Property

4.9.1 Chain of Custody

Chain of Custody apply throughout the ICT SCRM SDLC phases; therefore, refer to [Section 5.1 – Chain of Custody](#).

4.9.2 Anti-Tamper Testing/Inspection

Tamper Resistance and Detection apply throughout the ICT SCRM SDLC phases; therefore, refer to

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

Section 5.2 – Anti-Tamper and Detection.

4.9.3 Return of Government Furnished Property

Government furnished property (GFP) is property that is furnished to a contractor for performance of a USDA contract. There are two types of Government Furnished Property: Equipment and Material. Upon completion of the contract, [Contract/Vendor] is required to follow return of GFP in accordance with the latest publication of [NIST 800-88](#) - *Guidelines for Media Sanitization* and compliance in with best industry practices such as [Department of Defense 5220-22-M Standard](#) - *National Industrial Security Program (NISIP)*.

Upon completion of the delivery of the products and services to be provided under this Agreement, or at any time upon USDA's request, [Contractor/Sub-Contractor] will return to USDA all hardware and removable media provided by USDA containing USDA Information. USDA Information in returned hardware and removable media shall not be removed or altered in any way. The hardware should be physically sealed and returned via a bonded courier or as otherwise directed by USDA. If the hardware or removable media containing USDA Information is owned by [Contractor/Sub- Contractor] or a third-party, a notarized statement detailing the destruction method used and the data sets involved, the date of destruction, and the entity or individual who performed the destruction will be sent to a designated USDA security representative within fifteen (15) calendar days after completion of the delivery of the products and services to be provided under this Agreement, or at any time upon USDA's request. [Contractor/Sub-Contractor]'s destruction or erasure of USDA Information pursuant to this Section shall comply with best industry practices (e.g., Department of Defense 5220-22-M Standard, as may be amended). USDA will determine future disposition of government furnished equipment (i.e. disposal, recycle).

5 ALL-INCLUSIVE AREAS WITHIN ICT SCRM SDLC

This section contains activities that apply throughout the ICT SCRM SDLC; therefore [Contractor/Sub-Contractor] are to adhere to the all-inclusive areas without exception.

5.1 Chain of Custody

[Contractor/Sub-Contractor] is responsible for the end-to-end visibility and sensor technology that enables 24-7 monitoring of cargo which includes who touched it at either end; whether the cargo has deviated from its designated route; or whether the container or package has been opened in route. Sensors provide information on cargo conditions such as shock detectors, temperature, humidity, etc. These types of asset visibility measures safeguard both the physical security and quality of the shipment.

5.2 Tamper Resistance and Detection



INFORMATION TECHNOLOGY PROCEDURE

SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES

Version: 7.2A

[Contractor/Sub-Contractor] shall use a combination of hardware and software techniques for tamper resistance and detection. These techniques should include but not limited to obfuscation and self-checking to make reverse engineering and modifications more difficult, time-consuming, and expensive for adversaries. Strong identification combined with tamper resistance and/or tamper detection is essential to protecting information systems, components, and products during distribution and when in use.

5.3 Incidents

5.3.1 Vendor Identified Incidents

Whenever a security incident occurs, [Contractor/Sub-Contractor] agrees to notify USDA within # by telephone and email, and subsequently via written correspondence or form.

5.3.2 Incident Response

Upon any cyber incident, [Contractor/Sub-Contractor] will adhere to [USDA DR 3505-005](#) - *Cybersecurity Incident Management*.

Within # days of notifying USDA of the security incident, [Contractor/Sub-Contractor] shall recommend actions to be taken by USDA on USDA-controlled systems to reduce the risk of a recurrence of the same or a similar security incident, including, as appropriate, the provision of action plans and mitigating controls. [Contractor/Sub-Contractor] shall coordinate with USDA in developing those action plans and mitigating controls. [Contractor/Sub-Contractor] will provide USDA guidance and recommendations for long term remediation of any cybersecurity risks posed to USDA information, equipment, systems, and networks as well as any information necessary to assist USDA in any recovery efforts undertaken by USDA in response to the security incident.

5.3.3 Development and Implementation of a Response Plan

[Contractor/Sub-Contractor] shall develop and implement policies and procedures to address security incidents ("Response Plan") by mitigating the harmful effects of security incidents and remedying the occurrence to prevent the recurrence of security incidents in the future.

[Contractor/Sub-Contractor] shall provide USDA access to inspect its Response Plan. The development and implementation of the Response Plan shall follow best practices that at a minimum are consistent with the contingency planning requirements of the latest publication:

- NIST Special Publication 800-61 Rev. 2, Computer Security Incident Handling Guide
- NIST Special Publication 800-53 Rev. 4, Security and Privacy Controls for Federal Information Systems and Organizations
 - CP-1 through CP-137
 - IR-1 through IR-10

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

Immediately upon learning of a security incident related to the products and services provided to USDA, [Contractor/Sub-Contractor] shall implement its Response Plan and within 24 hours of implementing its Response Plan, shall notify USDA.

5.3.4 Prevention of Recurrence:

Within # days of a security incident, [Contractor/Sub-Contractor] shall develop and execute a plan that reduces the likelihood of the same or a similar security incident from occurring in the future consistent with the requirements of its Response Plan and NIST Special Publication 800- 61rev2 and NIST Special Publication 800-184, Guide for Cybersecurity Event Recovery (as may be amended) and shall communicate that plan to USDA. [Contractor/Sub-Contractor] shall provide recommendations to USDA on actions that USDA may take to assist in the prevention of recurrence, as applicable or appropriate.

5.3.5 Customer Notification (CN):

[Contractor/Sub-Contractor] will, at its sole cost and expense, assist and cooperate with USDA with respect to any investigation of a security incident, critical and high vulnerabilities and product flaws, disclosures to affected parties, and other remedial measures as requested by USDA in connection with a security incident or required under any applicable laws related to a Security Incident.

In the event a Security Incident results in USDA information being disclosed such that notification is required to be made to any person or entity, including without limitation any customer, shareholder, or current or former employee of USDA under any applicable laws, including privacy and consumer protection laws, or pursuant to a request or directive from a governmental authority, such notification will be provided by USDA, except as required by applicable law or approved by USDA in writing. USDA will have sole control over the timing and method of providing such notification.

5.4 Vulnerabilities

5.4.1 Disclosure and Remediation of Known Vulnerabilities by Vendor

[Contractor/Sub-Contractor] shall develop and implement policies and procedures to address the disclosure and remediation by [Contractor/Sub-Contractor] of vulnerabilities and material defects related to the products and services provided to USDA under this Agreement including the following:

- (a) Prior to the delivery of the procured product or service, [Contractor/Sub-Contractor] shall provide summary documentation of publicly disclosed vulnerabilities and material defects related in the procured product or services, the potential impact of such vulnerabilities and material defects, the status of [Contractor/Sub-Contractor]'s efforts to mitigate those publicly disclosed vulnerabilities and material defects, and [Contractor/Sub-Contractor]'s recommended corrective actions, compensating security controls, mitigations, and/or procedural workarounds.



INFORMATION TECHNOLOGY PROCEDURE

SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES

Version: 7.2A

- (b) [Contractor/Sub-Contractor] shall provide summary documentation of vulnerabilities and material defects in the procured product or services within thirty (30) calendar days after such vulnerabilities and material defects become known to [Contractor/Sub-Contractor]. This includes summary documentation on vulnerabilities that have not been publicly disclosed or have only been identified after the delivery of the product. The summary documentation shall include a description of each vulnerability and material defects and its potential impact, root cause, and recommended corrective actions, compensating security controls, mitigations, and/or procedural workarounds.
- (c) [Contractor/Sub-Contractor] shall disclose the existence of all known methods for bypassing computer authentication in the procured product or services, often referred to as backdoors, and provide written documentation that all such backdoors created by [Contractor/Sub-Contractor] have been permanently deleted or disabled.
- (d) [Contractor/Sub-Contractor] shall implement a vulnerability detection and remediation program consistent with the latest publication of NIST Special Publication 800-53 RA-5,18 SA-11/19 and SI-2 (as may be amended).

5.5 USDA's Audit Rights

USDA or its third-party designee may, but is not obligated to, perform audits and security tests of [Contractor/Sub-Contractor]'s IT or systems environment and procedural controls to determine [Contractor/Sub-Contractor]'s compliance with the system, network, data, and information security requirements of this Agreement. These audits and tests may include coordinated security tests, interviews of relevant personnel, review of documentation, and technical inspection of systems and networks as they relate to the receipt, maintenance, use, retention, and authorized destruction of USDA Information. [Contractor/Sub-Contractor] shall provide all information reasonably requested by USDA in connection with any such audits and shall provide reasonable access and assistance to USDA upon request. [Contractor/Sub-Contractor] will comply, within reasonable timeframes at its own cost and expense, with all reasonable recommendations that result from such inspections, tests, and audits. USDA reserves the right to view, upon request, any original security reports that [Contractor/Sub-Contractor] has undertaken or commissioned to assess [Contractor/Sub-Contractor]'s own network security. If requested, copies of these reports will be sent via bonded courier to USDA security contact. [Contractor/Sub-Contractor] will notify USDA of any such security reports or similar assessments once they have been completed. Any regulators of USDA or its affiliates shall have the same rights of audit as described herein upon request.

Evidence of compliance or successful documented operational implementation can be in the form of inspection/audit results, or artifacts related to applicable Supply Chain or Information Security Management System certifications (e.g. O-TTPS/ISO 20243:2018), or internal SCRM program test/inspection results related to quality, security, or supplier management programs.

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

5.6 Covered Telecommunication Equipment or Services (Section 889(a)(1)(B))

In support of FAR Case 2019-009 on Section 889(a)(1)(B) of the John S. McCain National Defense Authorization Act (NDAA) commonly referred to as “Section 889 Part”:

If the contractor confirms that it identified prohibited telecom used during contract performance and an existing waiver does not apply, the CO shall submit a Supply Chain Event Report to the SCRM Review Board, including, at a minimum:

- (1) A “critical date”, no less than three business days, for when a response from the SCRM Review Board is requested. The CO may proceed to the next step(s) below if the SCRM Review Board has not responded by the “critical date”.
- (2) The information provided by the offeror under paragraph (d) of the reporting clause at FAR 52.204-25.
- (3) Be aware that the SCRM Review Board may ask for additional information.

5.6.1 Identified Prohibited Telecom

If the contractor confirms that it identified prohibited telecom used during contract performance and there is no applicable waiver, the CO will need to determine whether or not an exception applies, if the prohibited telecom is not a substantial or essential component of a system, or if the prohibited telecom is not critical technology as part of any system.

- (1) The SCRM Review Board will provide to the CO, via response to the Supply Chain Event Report, information as to whether it thinks that continued performance or extension of the contract (or order) will result in a violation of the prohibition. If the SCRM Review Board has not responded by the “critical date”, the CO may decide without the SCRM Review Board’s input.
- (2) Resources for assisting the CO in making this determination, based on previous guidance provided by GSA’s SCRM Review Board, will be available on the Acquisition Portal at <http://insite.gsa.gov/scrm>.
- (3) If, after using such resources, the CO cannot make this determination on their own, the CO should consult with their acquisition team, technical experts, their management, and request additional assistance from the SCRM Review Board by contacting SCRM-Review-Board@gsa.gov.
- (4) If the CO determines that continued performance or extension of the contract (or order) will not result in a violation of the prohibition, the CO should document the file accordingly and may continue performance of and/or extend the contract (or order).

5.6.2 Exceptions Clarification

The statute includes two exceptions at 889 (a)(2)(A) and (B). (1) The exception at 889(a)(2)(A) allows the head of executive agency to procure with an entity “to provide a service that connects to the facilities of a third-party, such as backhaul, roaming, or interconnection arrangements”. (2) The exception at 889(a)(2)(B) allows an entity to procure “telecommunications equipment that cannot route or redirect user data traffic or [cannot] permit visibility into any user data or packets that such equipment transmits or otherwise handles.” **The exception**

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

allowing for procurement of services that connect to the facilities of a third-party, such as backhaul, roaming, or interconnection arrangements applies only to a Government agency that is contracting with an entity to provide a service. Therefore, the exception does not apply to a contractor's use of a service that connects to the facilities of a third-party, such as backhaul, roaming, or interconnection arrangements. As a result, the Federal Government is prohibited from contracting with a contractor that uses covered telecommunications equipment or services to obtain backhaul services from an internet service provider, unless a waiver is granted.

5.7 Environmental Risks

Without proper risk aversion strategies, the supply chains can be disrupted by environmental factors; therefore, all the environment-related legislation made by governments and other regulatory bodies should be followed.

Negative environmental impacts such as carbon emissions can be reduced; waste must be disposed of properly; and chemicals handled properly to protect the environment. To avoid the dangers of natural disasters, [Contractor/Sub-Contractor] must choose their location and mode of transport strategically. They should be flexible and responsive enough to absorb changes and capable enough to avoid any distortions in the supply chain.

6 APPENDICES

6.1 [Contractor/Sub-Contractor] Cybersecurity Policy / System Security Plan

[Contractor/Sub-Contractor] Cybersecurity Policy or System Security Plan: [Contractor/Sub- Contractor] will provide to USDA the [Contractor/Sub-Contractor]'s [Contractor/Sub-Contractor] Cybersecurity Policy or System Security Plan: [Contractor/Sub-Contractor] will provide to USDA the [Contractor/Sub-Contractor]'s cybersecurity policy, which shall be consistent with the latest publication of NIST Special Publications (SP) 800-39, NIST SP 800-37 , as may be amended. [Contractor/Sub-Contractor] will implement and comply with that cybersecurity policy.

The System Security Plan (SSP) contains information that is deemed non-disclosure, it contains the security posture of the system, the system diagrams, system interconnects, Topologies, System boundaries and all implemented and future controls to be implemented. It must be secured with enhancements.

Cybersecurity policy, which shall be consistent with the latest publication of NIST Special Publication 800-53, 800-37, 800-39 as may be amended. [Contractor/Sub-Contractor] will implement and comply with that cybersecurity policy. Any changes to [Contractor/Sub- Contractor]'s cybersecurity policy as applied to products and services provided to USDA under this Agreement and USDA Information that are inconsistent with the security requirements of the latest publication of NIST Special Publication 800-53 as may be

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

amended shall be subject to review and approval by USDA prior to implementation by [Contractor/Sub-Contractor].

6.2 Cybersecurity & Supply Chain Risk Management (SCRM) References

[Contractors/Sub-Contractors] entering into an agreement to provide service to Government activities are subject to cybersecurity and SCRM laws, regulations, standards, policies and reporting requirements. Additional and/or tailored cybersecurity and SCRM requirements may be included in individual Task Orders by the issuing agency OCO. The [Contractor/Sub-Contractor] shall ensure all applicable Commercial-Off-The-Shelf (COTS) and enabled products comply with ordering agency cybersecurity and SCRM requirements.

- a) Laws
 - The Clinger-Cohen Act of 1996, Pub. L. 104-106, Division E
 - The Federal Information Security Modernization Act of 2014, Pub. L. 113-283
 - Federal Information Technology Acquisition Reform Act (FITARA), Pub. L.113-291
 - The SECURE Technology Act, Pub. L.115-390
- b) Executive Orders
 - Executive Order 13859, Maintaining American Leadership in Artificial Intelligence
 - Executive Order 13873, Securing the Information and Communications Technology and Services Supply Chain
 - Executive Order 13833, Enhancing Effectiveness of Agency Chief Information Officers
 - Executive Order 13800, Strengthening the Cybersecurity of Federal Networks and Critical Infrastructure
 - Executive Order 13870, America's Cybersecurity Workforce
- c) Policies of the Committee on National Security Systems
 - The policies presented under this topic address national security systems issues from a broad perspective. They establish national-level goals and objectives, all of which are binding upon all U.S. Government departments and agencies.
 - <http://www.cnss.gov/CNSS/issuances/Policies.cfm>
- d) OMB Circulars and Memoranda
 - Circulars (<https://www.whitehouse.gov/omb/information-for-agencies/circulars/>)
 - A-130
 - A-123
 - A-108
 - A-11
 - Memoranda (<https://www.whitehouse.gov/omb/information-for-agencies/memoranda/>)



INFORMATION TECHNOLOGY PROCEDURE

SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES

Version: 7.2A

- M-19-18
 - M-19-17
 - M-19-03
 - M-19-02
 - M-19-01
 - M-18-23
 - M-18-12
 - M-17-25
 - M-16-04
 - M-15-14
- e) National Institute of Standards and Technology (NIST)
- Federal Information Processing Standards (FIPS)
 - <https://www.nist.gov/itl/fips-general-information>
 - <https://www.nist.gov/standardsgov/compliance-faqs-federal-information-processingstandards-fips>
- Special Publication 800-series and 1800-series
 - <https://www.nist.gov/itl/nist-special-publication-800-series-general-information>
 - <https://csrc.nist.gov/publications/sp800>
 - <https://www.nist.gov/itl/nist-special-publication-1800-series-general-information>
 - <https://csrc.nist.gov/publications/sp1800>
 - Framework for Improving Critical Infrastructure Cybersecurity
 - <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.04162018.pdf>
 - NICE Cybersecurity Workforce Framework Resource Center
 - <https://www.nist.gov/itl/applied-cybersecurity/nice/nice-cybersecurity-workforceframework-resource-center>
- f) Cybersecurity and Infrastructure Security Agency
- Information and Communications Technology Supply Chain Risk Management
 - Cybersecurity Maturity Model Certification (CMMC)
 - CMMC Accreditation Body
- g) National Defense Authorization Act of 2019
- Section 881: Permanent Supply Chain Risk Management Authority
 - Section 889: Prohibition on certain telecommunications and video surveillance services or



Be sure you are using the most current copy of this document, available from
the CIO Cybersecurity SecureCAP Website.

INFORMATION TECHNOLOGY PROCEDURE

SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES

Version: 7.2A

- equipment (FAR 52.204-24 and FAR 52.204-25)
- Sections 1631-1657: Cyber-spaced Related Matters

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

6.3 DEFINITIONS

Common definitions are provided below. For references to additional definitions, refer to www.Lexicon.com.

Company Information means for purposes of these terms and conditions, any and all information concerning USDA and its business in any form, including, without limitation, the products and services provided under this Agreement that is disclosed to or otherwise learned by [Contractor/Sub-Contractor] during the performance of this Agreement.
Company means the organization that acquires or procures a product or service.
Counterfeit electronic part means an unlawful or unauthorized reproduction, substitution, or alteration that has been knowingly mismarked, misidentified, or otherwise misrepresented to be an authentic, unmodified electronic part from the original manufacturer, or a source with the express written authority of the original manufacturer or current design activity, including an authorized aftermarket manufacturer. Unlawful or unauthorized substitution includes used electronic parts represented as new, or the false identification of grade, serial number, lot number, date code, or performance characteristics.
Disclosed means any circumstance when the security, integrity, or confidentiality of any USDA Information has been compromised, including but not limited to incidents where USDA Information has been damaged, lost, corrupted, destroyed, or accessed, acquired, modified, used, or disclosed by any unauthorized person, by any person in an unauthorized manner, or for an unauthorized purpose.
Electronic part means an integrated circuit, a discrete electronic component (including, but not limited to, a transistor, capacitor, resistor, or diode), or a circuit assembly (section 818(f)(2) of Pub. L. 112-81).
Government Furnished Equipment (GFE) - Government furnished equipment or “GFE” consists of equipment, special tooling, or special test equipment that is provided to a contractor for use on a Government contract (reference Federal Acquisition Regulations, Part 45).
Government Furnished Material (GFM) - Government furnished material (GFM) is another form of Government-owned property that is sometimes provided to contractors. Raw titanium for use in ship construction, nuts, bolts, washers, screws, and other consumable items are all examples of GFM. Material does not include equipment, special tooling, and special test equipment.
Hash - The hash is used to verify that data is not modified, tampered with, or corrupted. In other words, you can verify the data has maintained integrity.
Obsolete electronic part means an electronic part that is no longer available from the original manufacturer or an authorized aftermarket manufacturer.
Original component manufacturer means an organization that designs and/or engineers a part and is entitled to any intellectual property rights to that part.



Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.

INFORMATION TECHNOLOGY PROCEDURE

SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES

Version: 7.2A

Original equipment manufacturer means a company that manufactures products that it has designed from purchased components and sells those products under the company's brand name.

Original manufacturer means the original component manufacturer, the original equipment manufacturer, or the contract manufacturer.

Security Incident means any circumstance when (i) [Contractor/Sub-Contractor] knows or reasonably believes that USDA Information hosted or stored by the [Contractor/Sub-Contractor] has been disclosed; (ii) [Contractor/Sub-Contractor] knows or reasonably believes that an act or omission has compromised or may reasonably compromise the cybersecurity of the products and services provided to USDA by [Contractor/Sub- Contractor] or the physical, technical, administrative, or organizational safeguards protecting [Contractor/Sub- Contractor]'s systems or USDA's systems storing or hosting USDA Information; or (iii) [Contractor/Sub- Contractor] receives any complaint, notice, or communication which relates directly or indirectly to (A) [Contractor/Sub-Contractor]'s handling of USDA Information or [Contractor/Sub-Contractor]'s compliance with the data safeguards in this Agreement or applicable law in connection with USDA Information or (B) the cybersecurity of the products and services provided to USDA by [Contractor/Sub-Contractor].

Security Technical Implementation Guide (STIG) is a cybersecurity methodology for standardizing security protocols within networks, servers, computers, and logical designs to enhance overall security.

Supply Chain Risk Management (SCRM) means a systematic process for managing supply chain risk by identifying susceptibilities, vulnerabilities, and threats throughout the supply chain and developing mitigation strategies to combat those threats whether presented by the supplier, the supplied product and its sub- elements, or the supply chain (e.g., initial production, packaging, handling, storage, transport, mission operation, and disposal). CNNSD 50, SCRM

Supply Chain Risk means that an adversary may sabotage, maliciously introduce unwanted function, or otherwise subvert the design, integrity, manufacturing, production, distribution, installation, operation, or maintenance of an item of supply or a system to surveil, deny, disrupt, or otherwise degrade the function, use, or operation of a system (The Ike Skelton National Defense Authorization Act for Fiscal Year 2011, Section 806).

Suspect counterfeit electronic part means an electronic part for which credible evidence (including, but not limited to, visual inspection or testing) provides reasonable doubt that the electronic part is authentic.

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

6.4 Acronyms and Abbreviations

A&A	Assessment and Authorization
APL	Approved Product List
ATO	Authorization to Operate
CDM	Continuous Diagnostics and Monitoring
COR	Contracting Officer's Representative
COTS	Commercial Off-the-Shelf
CP	Contingency Plan
CUI	Controlled Unclassified Information
CWE	Common Weakness Enumeration
DISA	Defense Information Systems Agency
DOD	Department of Defense
DR	Departmental Regulation
FAR	Federal Acquisition Regulation
FIPS	Federal Information Processing Standards
FITARA	Federal Information Technology Acquisition Reform Act
FOCI	Foreign Ownership Control or Influence
GFE	Government-Furnished Equipment
GSA	General Services Administration
HSPD	Homeland Security Presidential Directive
IaaS	Infrastructure as a Service
ICT	Information and Communications Technology
ISC	Information Security Center
IT	Information Technology
NACI	National Agency Check with Written Inquiries

	Be sure you are using the most current copy of this document, available from the CIO Cybersecurity SecureCAP Website.
	INFORMATION TECHNOLOGY PROCEDURE SA-4/9/AU-16/SR-5/8/12 ACQUISITION PROCESS AND EXTERNAL SYSTEM SERVICES Version: 7.2A

NDA	National Defense Authorization Act
NICE	National Initiative for Cybersecurity Education
NISP	National Industrial Security Program
NIST	National Institute of Standards and Technology
NS	National Security
NSA	National Security Agency
OCIO	Office of the Chief Information Officer
OMB	Office of Management and Budget
OPM	Office of Personnel Management
OWASP	Open Web Application Security Project
PaaS	Platform as a Service
PDF	Portable Document Format
PIV	Personal Identity Verification
RMF	Risk Management Framework
SaaS	Software as a Service
SCRM	Supply Chain Risk Management
SDLC	Software Development Lifecycle
SOW	Statement of Work
SP	Special Publication
SSP	System Security Plan
STIG	Security Technical Implementation Guide
USDA	United States Department of Agriculture